


Comparando leis de privacidade:

# GDPR v. LGPD



DataGuidance
by OneTrust

## Sobre os autores

**Orientação de dados por OneTrust** fornece um conjunto de soluções de privacidade projetadas para ajudar as organizações a monitorar os desenvolvimentos regulatórios, mitigar riscos e alcançar conformidade global.

A plataforma DataGuidance by OneTrust inclui orientação focada em tópicos centrais (ou seja, GDPR, transferências de dados, notificação de violação, entre outros), gráficos transfronteiriços que permitem comparar regulamentos em várias jurisdições em um relance, um serviço diário de notícias personalizado e análise de especialistas .

Essas ferramentas, junto com nosso serviço de analista interno para ajudá-lo com suas perguntas de pesquisa específicas, fornecem uma solução econômica e eficiente para projetar e apoiar seu programa de privacidade.

**Baptista Luz Advogados** foi fundada em 2004 e cobre a maioria das áreas do direito societário. Seus clientes incluem empresas e grupos econômicos, nacionais e internacionais, fundos de investimento, investidores anjo e empresários. Também atua em outros setores da economia, notadamente publicidade, tecnologia, instituições financeiras, aeronáutica, telecomunicações, e-commerce, logística e saúde. O Baptista Luz possui uma equipa dedicada à Privacidade e Protecção de Dados, com profissionais de referência, que estão directamente envolvidos nas mais importantes discussões da área e que tratam do compliance da protecção de dados a nível global e nacional. O escritório possui escritórios em três diferentes cidades brasileiras (São Paulo, Florianópolis e Londrina), além de uma unidade em Miami.

### Contribuidores

**Orientação de dados por OneTrust:** Alexis Kateifides, Joel Bates, Nikos Papageorgiou, Rumer Ramsey, Bart van der Geest, Alice Marini, Pascale Arguinarena

**Baptista Luz Advogados:** Renato Leite Monteiro, Odélio Porto Junior, Gabriela Moribe

Créditos de produção de imagem:

Capa / p.5 / p.51: cnythzl / Coleção de assinaturas / istockphoto.com Chave de escala p6-49: enisaksoy / Coleção de assinaturas / istockphoto.com Ícone p.12-21: Moto-rama / coleção Essentials / istockphoto.com
Ícone p.22-23: AlexeyBlogoodf / Essentials collection / istockphoto.com Ícone p.25, 29-37: zak00 / Signature collection / istockphoto.com
Ícone p.38-45: AlexeyBlogoodf / coleção Essentials / istockphoto.com Ícone p.47-51: cnythzl / Coleção de assinaturas / istockphoto.com

# Índice


**Introdução** 5

**1 Escopo**

1.1. Âmbito pessoal 7

1.2. Alcance territorial 8

1.3. Escopo do material 10

**2 Definições-chave**

2.1. Dados pessoais 12

2.2. Pseudonimização 14

2.3. Controladores e processadores 16

2.4. Crianças 18

2,5. Pesquisa 20

**3 - Base legal** 22

**4 - Obrigações do controlador e do processador**

4.1. Transferências de dados 25

4.2. Registros de processamento de dados 29

4.3. Avaliação do impacto da proteção de dados Nomeação 31

4,4. do responsável pela proteção de dados Segurança de 33

4.5. dados e violações de dados Responsabilidade e boas 35

4,6. práticas 36

**5 Direitos individuais**

5.1. Direito de apagar 38

5,2 Direito de ser informado Direito 40

5,3. de se opor 41

5,4 Direito de acesso 43

5.5. Direito de não ser sujeito a discriminação para o exercício de direitos Direito à portabilidade 44

5,6. de dados 45

**6 Execução**

6.1. Penalidades monetárias 47

6,2 Autoridade supervisora 49

6.3. Recursos civis para indivíduos 51






# Introdução

Em 25 de maio de 2018, o Regulamento Geral de Proteção de Dados (Regulamento (UE 2016/679) ('GDPR') entrou em vigor. Em agosto de 2018, o Brasil aprovou a Lei nº 13.709 de 14 de agosto de 2018 que Dispõe sobre a Proteção de Dados Pessoais e altera a Lei Federal nº 12.965 de 23 de abril de 2014 ('LGPD'), com entrada em vigor prevista para 2020.

Ambas as leis são abrangentes em termos de âmbito pessoal, material e territorial. Por exemplo, tanto o GDPR quanto o LGPD se aplicam a organizações com presença na UE e no Brasil respectivamente, bem como a organizações que não estão fisicamente localizadas, mas que oferecem bens e serviços nas jurisdições ou processam dados pessoais nessas regiões . No entanto, deve-se notar que apenas o RGPD se aplica a organizações que, embora não tenham qualquer presença na UE, monitoram o comportamento de indivíduos na UE.

Além disso, ambos os atos legislativos aplicam-se ao tratamento de dados pessoais de pessoas singulares efetuado por controladores e processadores. Em particular, seu escopo de aplicação parece de longo alcance, pois ambos protegem os indivíduos, independentemente de sua nacionalidade ou status de residência. Esse princípio está explicitamente incluído no GDPR, enquanto no Brasil é previsto pela interpretação combinada com a Constituição da República Federativa do Brasil ('a Constituição').

Ambos também fornecem proteção especial para o processamento de dados pessoais sensíveis, bem como para o processamento de dados de crianças. No entanto, existem várias nuances entre as duas leis, por exemplo, no que diz respeito à base jurídica aplicável quando os dados sensíveis são processados.

Além disso, ambas as leis excluem de seu escopo o tratamento de dados anônimos, embora a LGPD afirme que os dados podem ser considerados pessoais quando usados para formular perfis de comportamento de uma pessoa física específica, se essa pessoa for identificada.

Outras semelhanças podem ser encontradas nos direitos aos quais os indivíduos estão autorizados, bem como nas obrigações a que os controladores e processadores estão sujeitos. No entanto, de acordo com o GDPR, os controladores e processadores devem nomear um responsável pela proteção de dados ('DPO') em circunstâncias específicas, bem como realizar uma Avaliação de Impacto da Proteção de Dados ('DPIA'). De acordo com o LGPD, apenas os controladores devem nomear um DPO, e nenhuma circunstância específica é definida; portanto, à primeira vista, todos os controladores precisam designar um, independentemente do tipo, volume e forma como os dados são processados.

Este Guia visa, portanto, destacar as semelhanças e diferenças entre os dois atos legislativos, a fim de ajudar as organizações a desenvolver suas atividades de compliance.

# Estrutura e visão geral do Guia

Este Guia fornece uma comparação das duas peças de legislação nas seguintes disposições principais:

1. Escopo
2. Principais definições
3. Base jurídica
4. Obrigações do controlador e do processador
5. Direitos dos indivíduos
6. Aplicação

Cada tópico inclui artigos e seções relevantes das duas leis, um resumo da comparação e uma análise detalhada das semelhanças e diferenças entre o GDPR e o LGPD.

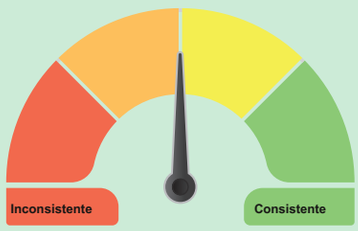
### Chave para dar a taxa de consistência

Consistente: O GDPR e o LGPD apresentam um alto grau de similaridade na lógica, no núcleo, no escopo e na aplicação da disposição considerada.

Bastante consistente: O GDPR e o LGPD apresentam um alto grau de similaridade na lógica, no núcleo e no escopo da disposição considerada; no entanto, os detalhes que regem sua aplicação são diferentes.

Bastante inconsistente: O GDPR e o LGPD apresentam várias diferenças no que diz respeito ao âmbito e aplicação da disposição considerada, no entanto a sua lógica e núcleo apresentam algumas semelhanças.

Inconsistente: O GDPR e o LGPD apresentam um elevado grau de divergência no que diz respeito à justificação, núcleo, âmbito e aplicação da disposição considerada.




# Uso do Guia

Este Guia é geral e educacional por natureza e não se destina a fornecer, e não deve ser considerado, como fonte de aconselhamento jurídico. As informações e materiais fornecidos no Guia podem não ser aplicáveis em todas (ou qualquer) situações e não devem ser objeto de ação sem aconselhamento jurídico específico com base em circunstâncias particulares.

Esta análise tem por base a versão da LGPD alterada pela Medida Provisória n.º 869, de 27 de dezembro de 2018, bem como uma tradução para o inglês da lei, elaborada pelo escritório de advocacia Pereira Neto | Macedo Advogados, e acessível em https: // www. pnm.adv.br/wp-content/uploads/2018/08/Brazilian-General-Data-Protection-Law.pdf. Orientação de dados por OneTrust e Baptista Luz Advogados gostaria de agradecer ao Pereira Neto | Macedo Advogados pelo empenho e pela disponibilização desta tradução para uso.

# 1. Escopo

## 1.1. Âmbito pessoal



Razoavelmente consistente

Tanto o GDPR quanto o LGPD protegem o processamento de dados pessoais de indivíduos. Além disso, o GDPR afirma que a proteção é fornecida independentemente da nacionalidade ou residência do titular dos dados, ao passo que o LGPD não aborda explicitamente este ponto. No entanto, ao fornecer uma interpretação de acordo com a Constituição, a proteção aplica-se a qualquer pessoa, independentemente da nacionalidade ou residência do titular dos dados. Ambas as leis se aplicam a controladores e processadores de dados.

| GDPR | LGPD |
|---|---|
| **Artigos 3, 4**<br>**Considerandos 2, 14, 22-25** | **Artigos 1-5** |

### Semelhanças

| | |
|---|---|
| O GDPR só protege os indivíduos vivos. Os dados pessoais de pessoas jurídicas não são cobertos pelo GDPR. O GDPR não protege os dados pessoais de pessoas falecidas, sendo deixados ao critério dos Estados-Membros. | O LGPD só protege explicitamente os dados pessoais de pessoas singulares. Portanto, os dados de pessoas jurídicas também não são abrangidos. |
| O Artigo 4 (1) do RGPD esclarece que um assunto de dados é 'uma pessoa física identificada ou identificável'. | O Artigo 5 (V) da LGPD esclarece que um assunto de dados é uma pessoa singular a quem se referem os dados pessoais objeto de tratamento. |
| O GDPR se aplica a controladores de dados e dados processadores, que podem ser empresas, organismos públicos, instituições, bem como organizações sem fins lucrativos. | O LGPD se aplica a controladores e processadores de dados, juntos chamados de em processamento agentes, quem pode ser empresas, organismos públicos, instituições, bem como organizações sem fins lucrativos. |
| O GDPR define um controlador de dados como 'a pessoa singular e coletiva, autoridade pública, agência ou outro organismo que, isoladamente ou em conjunto com outros, determina os fins e os meios de tratamento dos dados pessoais.' | O LGPD define um controlador como pessoa singular ou colectiva responsável pela tomada de decisões relativas ao tratamento de dados pessoais. |
| O GDPR define um processador de dados como «pessoa singular ou coletiva, autoridade pública, agência ou outro organismo que trata dados pessoais em nome do responsável pelo tratamento». | O LGPD define um processador enquanto pessoa singular ou colectiva, de direito público ou privado, que trata dados pessoais em nome do responsável pelo tratamento. |

### Diferenças

| | |
|---|---|
| O GDPR prevê que 'deve ser aplicado a pessoas, qualquer que seja sua nacionalidade ou local de residência, em relação ao tratamento dos seus dados pessoais. » | O LGPD faz não indique explicitamente se se aplica a naturais pessoas, independentemente da sua nacionalidade ou local de residência. |

## 1.2. Alcance territorial



**Razoavelmente consistente**

Tanto o GDPR quanto o LGPD se aplicam a entidades que estejam presentes na jurisdição. O GDPR se aplica a organizações que possuem um 'estabelecimento' na UE, enquanto o LGPD se aplica a operações de processamento de dados realizadas no Brasil.

Ambas as leis também têm alcance extraterritorial. Em particular, eles se aplicam a organizações que oferecem bens e serviços a titulares de dados na Europa e no Brasil, respectivamente, independentemente de onde eles estejam localizados. É de notar que apenas o RGPD se aplica a organizações que, embora não tenham qualquer presença na UE, monitorizam o comportamento de indivíduos na UE.

| GDPR | LGPD |
|---|---|
| **Artigos 3-4**<br>**Considerandos 2, 14, 22-25** | **Artigos 3-4** |

### Semelhanças

| | |
|---|---|
| O RGPD aplica-se a organizações com presença na UE, nomeadamente entidades que tenham um ' estabelecimento' na UE. Portanto, o GDPR se aplica ao processamento de dados pessoais por organizações estabelecido na UE, independentemente de quer o processamento seja realizado na UE ou não. | No que diz respeito à noção de estabelecimento, não existe qualquer disposição equivalente na LGPD que a defina. No entanto, o LGPD aplica-se a operações de processamento de dados realizadas no Brasil. A LGPD se aplica, independentemente da localização da sede de uma entidade, ou da localização dos dados sendo processados, se os dados sendo processados pertence a pessoas físicas localizadas no Brasil ou se os dados pessoais em tratamento foram coletados no Brasil. Dados coletados no Brasil são definidos como dados pertencer a um titular dos dados que estava no Brasil no momento da coleta. |
| Com relação à âmbito extraterritorial, o GDPR se aplica às atividades de processamento de organizações que não estão estabelecidos na UE, onde as atividades de processamento estão relacionadas ao oferta de bens ou serviços a particulares na UE. | O LGPD também se aplica, independentemente da localização da sede de uma entidade, ou da localização dos dados sendo processados, se o objetivo de uma entidade atividade de processamento é para oferecer ou fornecer bens ou serviços para pessoas físicas localizadas no Brasil. |

### Diferenças

| | |
|---|---|
| Em relação a âmbito extraterritorial, o GDPR aplica-se a organizações que não estão estabelecidas em a UE, mas monitorar o comportamento dos indivíduos, desde que o seu comportamento ocorra na UE. | Em relação a âmbito extraterritorial, o LGPD faz não incluir quaisquer disposições específicas em relação às atividades de processamento que tenham o objetivo de monitorar o comportamento das pessoas no Brasil. |
| Não há disposição equivalente no GDPR. | O Artigo 4 (IV) estabelece que a LGPD não se aplica a operações de processamento de dados, onde os dados estão sendo processados originado fora do Brasil, e não são o objeto de |

| GDPR | LGPD |
| --- | --- |
| **Diferenças (continuação)** | |
| | comunicação, uso compartilhado de dados com agentes de processamento brasileiros, ou objeto de transferência internacional de dados com outro país que não o Brasil, desde que o país de origem ofereça um nível de proteção adequado ao da LGPD. |
| O GDPR se aplica a pessoas físicas, tanto faz sua nacionalidade ou local de residência, em relação ao tratamento dos seus dados pessoais. | O LGPD não estabelecer explicitamente que será aplicável independentemente da nacionalidade ou local de residência do indivíduo. Entretanto, ao fornecer uma interpretação conforme a Constituição Federal Brasileira, a proteção se aplica a qualquer pessoa, independentemente da nacionalidade ou residência do titular dos dados. Além disso, o artigo 3º estabelece que a LGPD se aplicará se os dados pessoais em tratamento pertencerem a uma pessoa que estava no Brasil no momento de sua coleta. |

## 1.3. Escopo do material



Razoavelmente consistente

Ambas as leis se aplicam a dados pessoais definidos como informações sobre uma pessoa física identificada ou identificável. O GDPR exclui de sua aplicação o processamento de dados anônimos. Da mesma forma, a LGPD exclui de sua aplicação os 'dados anônimos', uma vez que não são considerados dados pessoais, a menos que o processo de anonimato tenha sido revertido. De acordo com a LGPD, os dados também podem ser considerados pessoais quando utilizados para formular perfis comportamentais de uma determinada pessoa física, caso essa pessoa seja identificada.

O GDPR aplica-se ao processamento de dados pessoais por meios automatizados ou não automatizados se os dados fizerem parte de um sistema de arquivo, enquanto o LGPD se aplica a qualquer operação de processamento.

| GDPR | LGPD |
|---|---|
| **Artigos 2-4, 9**<br>**Considerandos 15-21, 26** | **Artigos 3-5, 11-12** |

**Semelhanças**

O GDPR se aplica ao ' em processamento' de dados pessoais. A definição de 'processamento' abrange 'qualquer operação' realizada em dados pessoais ', como coleta, registro, organização, estruturação, armazenamento, adaptação ou alteração, recuperação, consulta, uso, divulgação por transmissão, disseminação ou de outra forma disponibilização, alinhamento ou combinação, restrição, apagamento ou destruição. '

O LGPD se aplica a qualquer operação de processamento, que é definida como qualquer operação realizada com dados pessoais, como coleta, produção, recebimento, classificação, uso, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, exclusão, avaliação ou controle da informação, modificação, comunicação , transferência, disseminação ou extração.

O GDPR se aplica ao em processamento de dados pessoais. ' Dados pessoais' é definido como 'qualquer informação' que se relaciona direta ou indiretamente com um indivíduo identificado ou identificável.

O LGPD se aplica a qualquer operação de processamento de dados pessoais. ' Dados pessoais' é definido como informação sobre uma pessoa física identificada ou identificável.

O GDPR define ' categorias especiais de dados pessoais ' como dados pessoais que revelam origem racial ou étnica, opiniões políticas, crenças religiosas ou filosóficas ou filiação em sindicatos e o processamento de dados genéticos, dados biométricos com o objetivo de identificar de forma única uma pessoa singular, dados relativos à saúde ou dados relativos a uma pessoa singular vida sexual ou orientação sexual. O GDPR fornece requisitos específicos para seu processamento.

O LGPD define ' dados pessoais sensíveis ' como dados pessoais relativos à origem racial ou étnica, crença religiosa, opinião política, filiação sindical ou religiosa, filosófica ou política, dados relativos à saúde ou vida sexual, dados genéticos ou biométricos, quando relacionados com uma pessoa singular. O LGPD fornece requisitos específicos para seu processamento.

O GDPR exclui de seu aplicativo o processamento de dados pessoais por indivíduos para fins puramente pessoais ou fins domésticos. Este é o processamento de dados que 'não tem conexão com uma atividade profissional ou comercial'.

A LGPD exclui de sua aplicação o processamento de dados pessoais por pessoas naturais para fins puramente privados e não econômicos.

| GDPR | LGPD |
| --- | --- |
| **Semelhanças (continuação)** | |
| O GDPR exclui dados anônimos da sua aplicação, que é definida como informação que não diz respeito a uma pessoa singular identificada ou identificável ou a dados pessoais tornados anónimos de tal forma que o titular dos dados não é ou deixa de ser identificável. | O LGPD exclui de sua aplicação dados anônimos, que é definida como dados relativos a um titular dos dados que não pode ser identificado, considerando a utilização de meios técnicos razoáveis e disponíveis no momento do processamento. |
| O GDPR exclui do processamento de dados de seu aplicativo dentro do contexto de aplicação da lei ou segurança nacional. | O LGPD exclui de seus dados de aplicativo processamento feito exclusivamente para fins de aplicação da lei e segurança nacional. |
| O GDPR fornece requisitos específicos para determinadas situações de processamento, incluindo processamento para jornalístico fins e expressão acadêmica, artística ou literária. | O LGPD geralmente não se aplica ao processamento de dados pessoais feito exclusivamente para segurança Pública, fins jornalísticos, artísticos ou acadêmicos. |
| **Diferenças** | |
| O GDPR se aplica ao processamento de dados pessoais dados por meios automatizados ou não automatizados se os dados fizerem parte de um sistema de arquivo. | O LGPD se aplica a qualquer operação de processamento. |
| O GDPR faz não abordar especificamente o processamento de dados anônimos para fins de criação de perfil. | A LGPD afirma que os dados podem ser considerados pessoais quando usados para formular perfis comportamentais de uma pessoa física específica, se essa pessoa for identificada. |

# 2. Principais definições

## 2.1. Dados pessoais




Tanto o GDPR quanto o LGPD fornecem definições de dados pessoais, dados pessoais confidenciais e dados anônimos que apresentam um alto grau de semelhança.

Em relação aos dados anônimos, para determinar se foram feitos esforços razoáveis para anonimizar os dados, a LGPD fornece critérios objetivos de análise, como tempo e custo, mas também inclui o controlador ou processador de uso de seus 'próprios recursos'. Além disso, de acordo com a LGPD, os dados anônimos podem ser considerados pessoais quando usados para formular perfis de comportamento de uma pessoa singular, se essa pessoa for identificada.

| GDPR | LGPD |
|---|---|
| **Artigos 4, 9**<br>**Considerandos 26-30** | **Artigos 5, 12** |

**Semelhanças**

O GDPR define 'dados pessoais' como ' qualquer informação relativa a uma pessoa singular identificada ou identificável (' dados sujeito'); uma pessoa física identificável é aquela que pode ser identificada, direta ou indiretamente, em particular por referência a um identificador, como um nome, um número de identificação, dados de localização, um identificador online ou um ou mais fatores específicos para o físico, fisiológico, identidade genética, mental, econômica, cultural ou social dessa pessoa natural. '

O LGPD define 'dados pessoais' como informações relacionadas a uma pessoa singular identificada ou identificável.

O GDPR faz não aplicar a dados anônimos, nomeadamente dados que não se referem a uma pessoa singular identificada ou identificável ou a dados pessoais tornados anónimos de tal forma que o titular dos dados não é ou deixa de ser identificável. O considerando 26 do RGPD prevê que «para determinar se uma pessoa singular é identificável, devem ser tidos em conta todos os meios razoavelmente prováveis de serem utilizados, como a seleção, pelo responsável pelo tratamento ou por outra pessoa, para identificar diretamente a pessoa singular ou indiretamente. Para determinar se os meios são razoavelmente prováveis de serem usados para identificar a pessoa natural, devem ser levados em consideração todos os fatores objetivos, como os custos e a quantidade de tempo necessária para a identificação, levando em consideração a tecnologia disponível no momento da processamento e desenvolvimentos tecnológicos. ' Portanto,

O LGPD faz não aplicar a dados anônimos, que é definida como dados relativos a um assunto que não pode ser identificado, direta ou indiretamente, considerando a utilização de meios técnicos razoáveis disponíveis no momento do processamento. No LGPD, os dados não são considerados anonimizados quando o processo de anonimização a que foram submetidos é reversível, considerando esforços razoáveis. Porém, para além dos critérios objetivos (custo, tempo e tecnologia disponível), a LGPD adota também um conceito subjetivo, que é o “uso de recursos próprios” do controlador ou processador para determinar se foram razoáveis os esforços envidados para o processo de anonimização.

| GDPR | LGPD |
| --- | --- |

## Semelhanças (continuação)

levando em consideração a tecnologia disponível no momento do processamento e os avanços tecnológicos.

O GDPR define categorias especiais de dados pessoais (ou 'dados sensíveis') como 'dados pessoais que revelam origem racial ou étnica, opiniões políticas, crenças religiosas ou filosóficas ou filiação em sindicatos e o processamento de dados genéticos, dados biométricos com o objetivo de identificar de forma única uma pessoa singular, dados relativos à saúde ou dados relativos a um natural vida sexual ou orientação sexual da pessoa. ' O processamento desta categoria de dados pessoais é proibido, salvo exceções aplicáveis. Veja 'Base Legal' abaixo.

O LGPD define ' dados sensíveis' como dados pessoais de origem racial ou étnica, crença religiosa, opinião política, filiação a sindicatos ou organização religiosa, filosófica ou política, saúde ou vida sexual, dados genéticos ou biométricos, quando ligados a uma pessoa física. A LGPD não proíbe o processamento de dados sensíveis, mas as bases legais para tal processamento são mais restritas. Veja 'Base Legal' abaixo.

## Diferenças

O GDPR não trata especificamente do processamento de dados anônimos no contexto de criação de perfil.

A LGPD declara que, se dados anônimos forem usados para criar ou aprimorar um perfil de comportamento de uma pessoa física, eles podem ser considerados dados pessoais quando o titular dos dados puder ser identificado.

# 2.2. Pseudonimização



Razoavelmente consistente

A definição de 'pseudonimização' incluída em ambos os atos legislativos é bastante semelhante. No entanto, o GDPR afirma que os dados pseudonimizados devem ser considerados dados pessoais, enquanto o LGPD não é explícito sobre isso. No entanto, considerando que, no LGPD, o conceito de dados pessoais inclui dados que podem identificar indiretamente um titular dos dados, os dados pseudonimizados podem ser considerados dados pessoais. Além disso, a 'pseudonimização' só está prevista quando a finalidade do processamento estiver relacionada à pesquisa em saúde.

Ambos os atos legislativos mencionam o processo de pseudonimização como uma salvaguarda que deve ser adotada para reduzir os riscos para os direitos dos titulares dos dados. No entanto, o LGPD apenas prevê explicitamente o uso de dados pseudonimizados no contexto da pesquisa em saúde pública.

| GDPR | LGPD |
|---|---|
| **Artigos 4, 11**<br>**Considerandos 26, 28-29** | **Artigo 13** |

## Semelhanças

' Pseudonimização ' é definido no GDPR como 'o processamento de dados pessoais de forma que os dados pessoais não possam mais ser atribuídos a um titular de dados específico sem o uso de informações adicionais, desde que tais informações adicionais sejam mantidas separadamente e estejam sujeitas a procedimentos técnicos e medidas organizacionais para garantir que os dados pessoais não sejam atribuídos a uma pessoa singular identificada ou identificável. '

' Pseudonimização ' é definido no LGPD como o processo pelo qual os dados não podem mais ser direta ou indiretamente associados a um indivíduo, exceto pelo uso de informações adicionais mantidas separadamente pelo controlador em um ambiente controlado e seguro.

## Diferenças

O GDPR afirma claramente que 'os dados pessoais que foram submetidos a pseudonimização e que podem ser atribuídos a uma pessoa física pelo uso de informações adicionais devem ser considerados como informações sobre uma pessoa física identificável'.

O LGPD faz não declarar explicitamente que os dados pseudonimizados devem ser considerados dados pessoais, no entanto, podem ser interpretados como tal, uma vez que a definição dada indica a possibilidade de reidentificação.

A LGPD prevê que nos estudos de saúde pública, as entidades de investigação que tenham acesso a dados pessoais, devam tratar os dados exclusivamente dentro da entidade e estritamente para efeitos de realização de estudos e inquéritos em ambiente controlado e seguro, incluindo, sempre que

possível, a anonimização ou pseudonimização do

dados. Uma 'entidade de pesquisa' é definida na LGPD como um órgão ou entidade legal da administração pública direta ou indireta ou

| GDPR | LGPD |
| --- | --- |
| **Diferenças (continuação)** | |
| | pessoa jurídica de direito privado, sem fins lucrativos, legalmente constituída de acordo com a legislação brasileira, com sede e foro no Brasil, que inclua em sua missão institucional ou em seus fins estatutários o objetivo de realizar pesquisa básica ou aplicada de caráter histórico, científico, natureza tecnológica ou estatística. |

## 2.3. Controladores e processadores




As definições de controlador e processador no GDPR e no LGPD apresentam um alto grau de similaridade.

O GDPR exige que a relação entre o controlador e o processador seja regida por um contrato ou outro ato jurídico. Pelo contrário, a LGPD limita-se a afirmar que o processador deve realizar o processamento de acordo com as instruções fornecidas pelo controlador, que é responsável por verificar o cumprimento das mesmas.

| GDPR | LGPD |
|---|---|
| **Artigos 4, 28, 30, 82** | **Artigo 5, 37-40, 42-43** |

**Semelhanças**

| | |
|---|---|
| UMA controlador de dados é definido no GDPR como 'a pessoa física ou jurídica, autoridade pública, agência ou outro órgão que, sozinho ou em conjunto com outros, determina as finalidades e meios de tratamento de dados pessoais; onde os propósitos e os meios para esse tratamento são determinados pela legislação da União ou dos Estados-Membros, o responsável pelo tratamento ou os critérios específicos para a sua nomeação podem ser previstos na legislação da União ou dos Estados-Membros. » | UMA controlador de dados é definida na LGPD como a pessoa singular ou colectiva, pública ou privada, que é responsável pelas decisões relativas ao tratamento de dados pessoais. |
| UMA processador de dados é definido no GDPR como 'uma pessoa física ou jurídica, a autoridade pública, agência ou qualquer outra entidade que processa dados pessoais em nome do responsável pelo tratamento'. | UMA processador de dados é definida na LGPD como a pessoa singular ou coletiva, pública ou privada, que efetua o tratamento de dados pessoais por conta do responsável pelo tratamento. |
| Sob o GDPR, o controlador e o processador devem manter sob o processamento sob sua responsabilidade. | LGPD, o controlador e o processador devem manter um registro das atividades de um registro das operações de processamento de dados pessoais que realizam, especialmente quando baseadas em interesses legítimos. |
| Nos termos do GDPR, «qualquer responsável pelo tratamento envolvido no tratamento é responsável pelos danos causados pelo tratamento que infringe o presente regulamento. O transformador só será responsável pelos danos causados pelo tratamento se não tiver cumprido as obrigações do presente regulamento especificamente dirigidas aos transformadores ou se tiver agido de forma contrária ou contrária às instruções legais do responsável pelo tratamento. » | Os responsáveis pelo tratamento diretamente envolvidos no tratamento de que o titular dos dados sofreu danos são solidariamente responsáveis. O processador é solidariamente responsável pelos danos causados pelo processamento quando não cumpre as obrigações da LGPD ou quando não segue as instruções legais do controlador, caso em que o processador se responsabiliza pelo controlador. Os processadores também são solidariamente responsáveis pelos danos causados pelo processamento nos casos em que não cumpram as obrigações e instruções do controlador. |

| GDPR | LGPD |
| --- | --- |
| **Semelhanças (continuação)** | |
| O controlador ou processador está isento de responsabilidade se provar que não é de forma alguma responsável pelo evento que deu origem ao dano. | Os agentes de processamento não serão responsabilizados quando puderem comprovar: (i) não participaram do processamento dos dados; (ii) quando, apesar do dano, o processamento for realizado de acordo com a LGPD; e (iii) o dano é devido à culpa exclusiva do titular dos dados ou de terceiros. |
| **Diferenças** | |
| O GDPR exige que o processamento por um processador seja regido por um contrato ou outro ato jurídico, 'que vincule o processador em relação ao controlador e que estabeleça o assunto e a duração do processamento, a natureza e a finalidade do tratamento, o tipo de dados pessoais e as categorias de titulares dos dados e as obrigações e direitos do responsável pelo tratamento. » | A LGPD simplesmente afirma que o operador deve conduzir o processamento de acordo com as instruções fornecidas pelo controlador, que é responsável por verificar o cumprimento. Nos termos da LGPD, não há obrigação de celebração de contrato ou outro ato jurídico para o tratamento realizado por um processador. |
| O GDPR não aborda especificamente esse ponto. | O agente processador será solidariamente responsável quando o processamento consistir em atendimento ao consumidor, uma vez que desencadeia a aplicação do Código de Defesa do Consumidor, Lei nº 8.078, de 11 de setembro de 1990. |

## 2.4. Crianças



Bastante inconsistente

Tanto o GDPR quanto o LGPD concedem proteção especial aos dados pessoais das crianças.

No que diz respeito ao consentimento para serviços da sociedade da informação, o RGPD fixa a idade mínima em 16 anos, embora os Estados-Membros possam definir uma idade inferior, respeitando o mínimo de 13 anos. Abaixo dessa idade, o consentimento deve ser dado por um dos pais ou tutor legal.

De acordo com a LGPD, o consentimento pode ser dado por uma pessoa física de 13 a 18 anos, desde que o tratamento de seus dados pessoais seja feito no seu melhor interesse. Nos casos em que as crianças têm menos de 13 anos, o consentimento específico e proeminente deve ser dado por um pai ou pessoa responsável pela criança. A definição de idade de crianças e adolescentes é fornecida pelo Estatuto Federal da Criança e do Adolescente 8069/1990.

| GDPR | LGPD |
|---|---|
| **Artigos 6, 8, 12, 40, 57,**<br>**Considerandos 38, 58, 75** | **Artigo 14** |

### Semelhanças

O GDPR declara que qualquer informação e comunicação, dirigida a uma criança, deve ser fornecida em tal linguagem clara e simples que a criança pode entender facilmente.

A LGPD afirma que as informações sobre o processamento de dados de crianças devem ser fornecidas em um forma simples, clara e acessível, utilizar recursos audiovisuais quando for o caso, a fim de fornecer as informações necessárias aos pais ou representante legal e adequadas ao entendimento da criança.

O GDPR requer que os controladores façam esforços razoáveis verificar se o consentimento foi dado ou autorizado por um dos pais ou responsável pela criança, levando em consideração a tecnologia disponível.

A LGPD afirma que o controlador deve fazer todos os esforço razoável verificar se o consentimento foi dado pelo representante da criança, considerando as tecnologias disponíveis.

### Diferenças

O GDPR aborda explicitamente o consentimento das crianças apenas no contexto da oferta de serviços da sociedade da informação.

O LGPD trata do consentimento das crianças com relação a qualquer processamento de seus dados pessoais. O consentimento pode ser prestado por pessoa singular dos 13 aos 18 anos, desde que o tratamento dos seus dados pessoais seja efectuado no seu superior interesse. No caso de crianças menores de 13 anos, consentimento específico e proeminente deve ser dado por um pai ou pessoa responsável pela criança. A definição de idade de crianças e adolescentes é fornecida pelo Estatuto Federal da Criança e do Adolescente.

| GDPR | LGPD |
| --- | --- |
| **Diferenças (continuação)** | |
| De acordo com o GDPR, a idade mínima para consentir com os serviços da sociedade da informação é 16, mas os Estados-Membros podem prever uma idade inferior para esses fins, desde que essa idade inferior não seja inferior 13 anos. | De acordo com o LGPD, a idade mínima para consentimento é 13 anos velho. |
| De acordo com o GDPR, o consentimento de um dos pais ou representante legal não deve ser necessário no contexto de serviços preventivos ou de aconselhamento oferecidos diretamente a uma criança. | Ao abrigo da LGPD, é possível recolher dados de crianças sem consentimento quando necessário para contactar os pais ou representantes legais, utilizados uma vez e sem armazenamento, ou para a sua protecção, e em nenhum caso podem ser partilhados com terceiros sem o devido consentimento. |
| O GDPR declara que a proteção específica deve, em particular, se aplicar ao uso de dados pessoais de crianças para fins de marketing ou criação de perfis de personalidade ou de usuário e a coleta de dados pessoais relativos a crianças ao usar serviços oferecidos diretamente a uma criança. | De acordo com a LGPD, os controladores não devem condicionar a participação de crianças em jogos, aplicativos de internet ou outras atividades ao fornecimento de informações pessoais além do estritamente necessário para a atividade. |

# 2,5. Pesquisa



**Bastante inconsistente**

As disposições do GDPR sobre pesquisa são mais flexíveis do que as do LGPD. Em particular, o LGPD fornece uma definição restritiva de 'organismo de pesquisa', enquanto o GDPR afirma que a pesquisa científica deve ser interpretada de uma 'maneira ampla'.

As regras relativas ao processamento de pesquisas em saúde pública são bastante semelhantes, porém, as disposições do LGPD são mais restritivas do que o GDPR, pois proíbe a transferência de dados a terceiros, estabelecendo que o processamento deve ser realizado dentro do próprio órgão de pesquisa.

| GDPR | LGPD |
|---|---|
| **Artigos 5, 9, 14, 17, 89, considerandos 33, 159-161** | **Artigos 5, 7, 11, 13, 16** |

## Semelhanças

De acordo com o GDPR, o processamento de dados sensíveis não é proibido quando 'necessário para fins de arquivamento de interesse público, fins de pesquisa científica ou histórica ou
fins estatísticos, que devem ser proporcionais ao objetivo prosseguido, respeitar o conteúdo essencial do direito à proteção de dados e prever medidas adequadas e específicas para salvaguardar os direitos fundamentais e os interesses do titular dos dados ».

Sob o LGPD, dados sensíveis podem ser processados para que um órgão de pesquisa conduza seus estudos. Neste caso, o LGPD
também recomenda o anonimato de dados pessoais sensíveis.

De acordo com o GDPR, categorias especiais de dados pessoais que merecem maior proteção devem ser processadas para fins relacionados à saúde apenas quando necessário para atingir esses fins em benefício de pessoas físicas e da sociedade como um todo, por exemplo, no contexto de estudos realizados no interesse público na área da saúde pública.

De acordo com a LGPD, o processamento de dados pessoais para fins de pesquisa em saúde pública deve ser conduzido exclusivamente dentro do corpo de pesquisa e estritamente para fins de realização de estudos e pesquisas e mantidos em um ambiente controlado e seguro de acordo com as práticas de segurança, incluindo anonimização ou pseudonimização dos dados.

## Diferenças

De acordo com o GDPR, o processamento de dados pessoais para fins de pesquisa científica deve ser interpretado 'de uma maneira ampla, incluindo, por exemplo, desenvolvimento tecnológico e demonstração, pesquisa fundamental, pesquisa aplicada e pesquisa com financiamento privado'.

A pesquisa científica não está definida no LGPD. Nos termos da LGPD, um 'órgão de pesquisa' é definido como o órgão ou entidade da administração pública ou pessoa jurídica de organização privada sem fins lucrativos, com sede e jurisdição no Brasil, que inclui em sua missão institucional ou em seu objetivo societário ou estatutário básico ou pesquisa aplicada de natureza histórica, científica, tecnológica ou estatística. A base legal de 'investigação' só é válida para estudos realizados por organismos de investigação que se enquadrem na definição acima mencionada. Portanto, as entidades que realizam pesquisas para obter vantagens econômicas não podem contar com a base jurídica da pesquisa para o tratamento de dados pessoais.

| GDPR | LGPD |
| --- | --- |
| **Diferenças (continuação)** | |
| Nos termos do GDPR, quando os dados pessoais são processados para fins de arquivo no interesse público e para fins de investigação, é possível aos Estados-Membros derrogar os direitos de algumas pessoas em causa, na medida em que tais direitos possam tornar impossível ou prejudicar seriamente a realização de objetivos específicos, e tais derrogações são necessárias para o cumprimento desses objetivos. | De acordo com a LGPD, não há derrogações para os direitos dos titulares dos dados quando o processamento for para fins de pesquisa. |
| O RGPD prevê que «o tratamento posterior para fins de arquivo de interesse público, para fins de investigação científica ou histórica ou para fins estatísticos não deve, nos termos do artigo 89.º, n.º 1, ser considerado incompatível com os objetivos iniciais». | Não há disposição equivalente na LGPD. |

# 3. Base jurídica




Tanto o GDPR quanto o LGPD exigem a identificação de uma base legal para o processamento de dados pessoais. Algumas bases jurídicas são semelhantes; no entanto, os dois atos legislativos também preveem bases jurídicas diferentes.

| GDPR | LGPD |
|---|---|
| **Artigos 5-10**<br>**Considerandos 39-48** | **Artigos 7-13** |

## Semelhanças

| | |
|---|---|
| De acordo com o GDPR, as bases jurídicas para o processamento de dados pessoais são: ( Eu) consentimento dados pelo titular dos dados para uma ou mais finalidades específicas; (ii) quando necessário para o execução de um contrato em que o titular dos dados seja parte ou para tomar medidas a pedido do titular dos dados antes de celebrar um contrato; (iii) quando necessário para cumprimento de uma obrigação legal a que o controlador está sujeito; (iv) quando necessário, a fim de proteger os interesses vitais do titular dos dados ou de outra pessoa física; (v) quando necessário para o desempenho de uma tarefa realizada no interesse público ou no exercício de autoridade oficial investida no controlador; e (vi) quando necessário para os fins do interesses legítimos Prosseguidos pelo responsável pelo tratamento ou por terceiros, exceto se esses interesses forem anulados pelos interesses ou direitos e liberdades fundamentais do titular dos dados que requeiram a proteção dos dados pessoais, nomeadamente quando o titular dos dados for uma criança. O processamento de dados pessoais estritamente necessários para o fins de prevenção de fraude também constitui um interesse legítimo do responsável pelo tratamento dos dados em causa. O processamento de dados pessoais para fins de marketing direto pode ser considerada realizada por um interesse legítimo. | De acordo com o LGPD, as bases jurídicas para o processamento de dados pessoais são: ( i) a provisão de consentimento pelo titular dos dados; (ii) quando necessário para o execução de um contrato ou procedimentos preliminares relativos a um contrato do qual o titular seja parte, a pedido do titular dos dados; (iii) para o cumprimento de uma obrigação legal ou regulatória pelo controlador; (iv) para o proteção da vida ou física segurança do titular dos dados ou de terceiros; (v) pela administração pública, para o tratamento e uso compartilhado de dados necessários à execução de políticas públicas previstas em leis e regulamentos ou amparadas em contratos, acordos ou instrumentos semelhantes; e (vi) quando necessário para atender a interesses legítimos do responsável pelo tratamento ou de terceiros, exceto no caso dos direitos e liberdades fundamentais do titular dos dados que requeiram a proteção de dados pessoais. |
| De acordo com o GDPR, as bases jurídicas para o processamento de dados pessoais sensíveis são: ( i) o titular dos dados forneceu consentimento explícito; ( ii) quando necessário para os fins de cumprir as obrigações e exercer as direitos do controlador ou do titular dos dados no campo de emprego e segurança social e proteção social; (iii) onde controlador; (iii) quando necessário para o proteção do necessário para proteger o interesses vitais do titular dos dados ou de outra pessoa física em que o titular dos dados seja física ou legalmente incapaz de dar o consentimento; (iv) quando necessário para a estabelecimento, exercício ou defesa de ações judiciais ou | De acordo com o LGPD, as bases jurídicas para o processamento de dados pessoais sensíveis são: ( i) quando o titular dos dados ou seu representante legal consentimentos, específica e distintamente, de maneira separada, para fins específicos, (ii) quando necessário para conformidade com um obrigação legal ou regulatória pelo vida ou segurança física do titular dos dados ou de terceiros; (iv) onde necessário para o exercício regular de direitos, incluindo no contrato e no judicial, processos administrativos e arbitrais, esta última nos termos da Lei nº 9.307, |

| GDPR | LGPD |
|---|---|

## Semelhanças (continuação)

sempre que os tribunais estiverem agindo em sua capacidade judicial; (v) quando necessário por razões de substancial interesse público,
com base na legislação da União ou dos Estados-Membros, que deve ser proporcional ao objetivo prosseguido, respeitar o conteúdo essencial do direito à proteção de dados e prever medidas adequadas e específicas para salvaguardar os direitos fundamentais e os interesses do titular dos dados; (vi) quando necessário para o
fins de medicina preventiva ou ocupacional, para o
avaliação da capacidade de trabalho do trabalhador, diagnóstico médico, prestação de cuidados ou tratamentos de saúde ou sociais ou gestão de sistemas e serviços de saúde ou de cuidados sociais com base na legislação da União ou dos Estados-Membros ou nos termos de contrato com um profissional de saúde ; (vii) onde
necessário por razões de interesse público na área de público
saúde, tais como a proteção contra graves ameaças transfronteiriças à saúde ou a garantia de elevados padrões de qualidade e segurança dos cuidados de saúde e de medicamentos ou dispositivos médicos, com base na legislação da União ou dos Estados-Membros que prevê medidas adequadas e específicas para salvaguardar o direitos e liberdades do titular dos dados, em especial sigilo profissional; e (viii) quando necessário para fins de arquivamento em
a interesse público, fins de pesquisa científica ou histórica
ou fins estatísticos com base na legislação da União ou dos Estados-Membros, que deve ser proporcional ao objetivo prosseguido, respeitar o conteúdo essencial do direito à proteção de dados e prever medidas adequadas e específicas para salvaguardar os direitos fundamentais e os interesses do titular dos dados.

de 23 de setembro de 1996 (Lei de Arbitragem); (v) tratamento compartilhado de dados necessários à execução, pela administração pública, de políticas publicas previsto em leis ou regulamentos; e (vi) proteção da saúde, em procedimento realizado por profissionais de saúde ou por entidades de saúde.

## Diferenças

Não existem outras bases jurídicas ao abrigo do GDPR para o processamento de dados pessoais.

As bases jurídicas que somente a LGPD fornece no que diz respeito ao tratamento de dados pessoais incluem: (i) conduzir
estudos por um órgão de pesquisa, garantindo, sempre
possível, a anonimização de dados pessoais; (ii) para o exercício regular
dos direitos em judicial, administrativo ou
procedimentos arbitrais; ( iii) para o proteção da saúde, em um
procedimento realizado por profissionais de saúde ou pela saúde
entidades; (iv) quando necessário para proteção de crédito.

| GDPR | LGPD |
| --- | --- |

## Diferenças (continuação)

As bases jurídicas que apenas o GDPR prevê em relação ao processamento de dados confidenciais incluem: (i) onde o processamento é realizado no curso de sua atividades legítimas com as salvaguardas adequadas por uma fundação, associação ou qualquer outro órgão sem fins lucrativos com um objetivo político, filosófico, religioso ou sindical e na condição de que o processamento diga respeito apenas aos membros ou ex-membros do órgão ou a pessoas que ter contacto regular com o mesmo no âmbito dos seus fins e que os dados pessoais não sejam divulgados fora desse órgão sem o consentimento dos titulares dos dados; e (ii) quando o processamento se relaciona com dados pessoais que são manifestamente tornados públicos pelo titular dos dados.

As bases legais que apenas a LGPD prevê em relação ao tratamento de dados sensíveis incluem: (i) para garantindo o prevenção de fraude e segurança do titular dos dados, no processos de identificação e autenticação de registo em sistemas electrónicos, salvaguardando os direitos referidos no artigo 9.º e salvo quando prevaleçam direitos e liberdades fundamentais do titular dos dados que requeiram protecção de dados pessoais.

# 4. Obrigações do controlador e do processador

## 4.1. Transferências de dados



Razoavelmente consistente

Tanto o GDPR como o LGPD prevêem a transferência de dados pessoais para países terceiros ou organizações internacionais apenas por motivos específicos. Ambos os atos legislativos reconhecem o conceito de adequação, bem como outros fundamentos jurídicos para a base da transferência internacional de dados.

Apesar do elevado nível de semelhança no núcleo da disposição, o GDPR inclui requisitos mais prescritivos sobre as condições legais para a transferência de dados pessoais.

| GDPR | LGPD |
|---|---|
| **Artigos 44-50**<br>**Considerandos 101, 112** | **Artigos 33-35** |

**Semelhanças**

O GDPR permite a transferência internacional de pessoal dados a um país terceiro, a um território ou a um ou mais setores especificados desse país terceiro, ou a uma organização internacional que garanta um nível de proteção adequado, conforme avaliado pela Comissão Europeia. Na ausência de uma decisão de adequação, a transferência é permitida quando o responsável pelo tratamento ou subcontratante proporcionou as salvaguardas adequadas por meio de: (i) regras societárias vinculativas; (ii) cláusulas-padrão de proteção de dados adotadas pela Comissão Europeia ou por uma autoridade de supervisão; (iii) um código de conduta aprovado; e (iv) um mecanismo de certificação aprovado.

O LGPD permite a transferência internacional de pessoal dados a países ou organizações internacionais que proporcionem um nível adequado de proteção de dados pessoais, ou quando o responsável pelo tratamento garanta o cumprimento do regime de proteção de dados por meio de: (i) cláusulas contratuais específicas para uma determinada transferência; (ii) cláusulas contratuais padrão; (iii) regras corporativas globais; e (iv) selos de qualidade, certificados e códigos de conduta válidos.

Outros fundamentos legais com base nas quais as transferências de dados são permitidas são: (i) a cooperação judiciária por meio de acordos internacionais; (ii) quando o titular dos dados tiver consentido explicitamente; (iii) quando a transferência for necessária para a execução ou celebração de um contrato; (iv) quando a transferência for necessária por razões importantes de interesse público; (v) quando a transferência for necessária para o estabelecimento, exercício ou defesa de ações judiciais; e (vi) quando a transferência for necessária para proteger interesses vitais do titular dos dados ou de outras pessoas.

Outros fundamentos legais com base nos quais as transferências de dados são permitidas são: (i) quando a transferência é necessária para cooperação jurídica entre agências de aplicação da lei, de acordo com instrumentos de direito internacional; (ii) quando a transferência for necessária para proteger a vida ou a segurança física do titular dos dados ou de terceiros; (iii) quando o titular dos dados deu um consentimento específico e pendente para as transferências; (iv) quando a transferência for necessária para a execução de um contrato ou procedimentos preliminares relacionados a um contrato; (v) quando a transferência for necessária para o exercício regular de direitos em procedimentos judiciais, administrativos ou arbitrais; e (vi) quando a transferência for necessária à execução de ordem pública ou atribuição legal de serviço público.

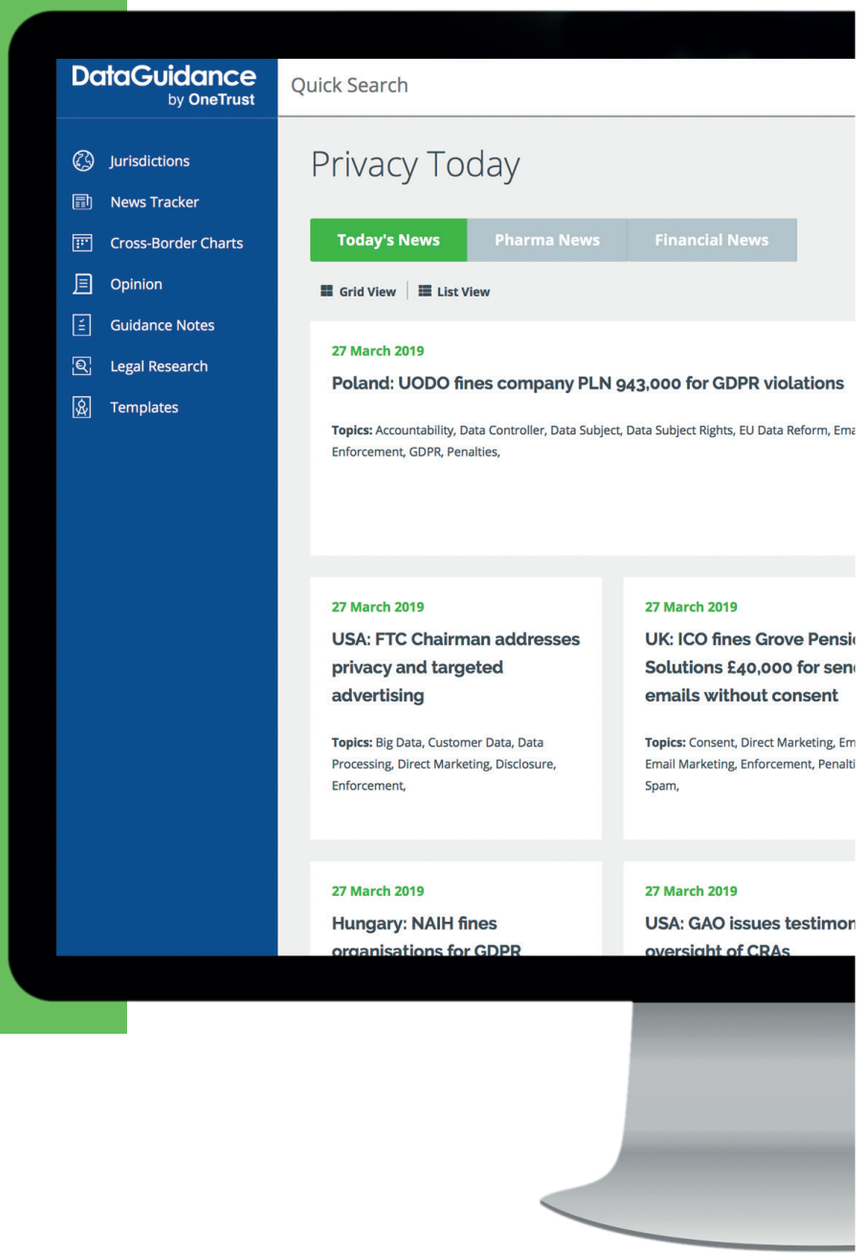
# DataGui

## Portal GDPR

O recurso mais abrangente para o desenvolvimento e manutenção do seu programa GDPR.

- Entenda as obrigações e requisitos em todos os principais tópicos e setores
- Acompanhe os desenvolvimentos em relação Implementação do Estado Membro e orientação regulatória
- Aplique inteligência especializada para tomar decisões de negócios
- Utilize listas de verificação e modelos específicos do GDPR

DataGuidance by OneTrust é uma plataforma
para monitorar desenvolvimentos regulatóri
mitigar riscos e alcançar conform



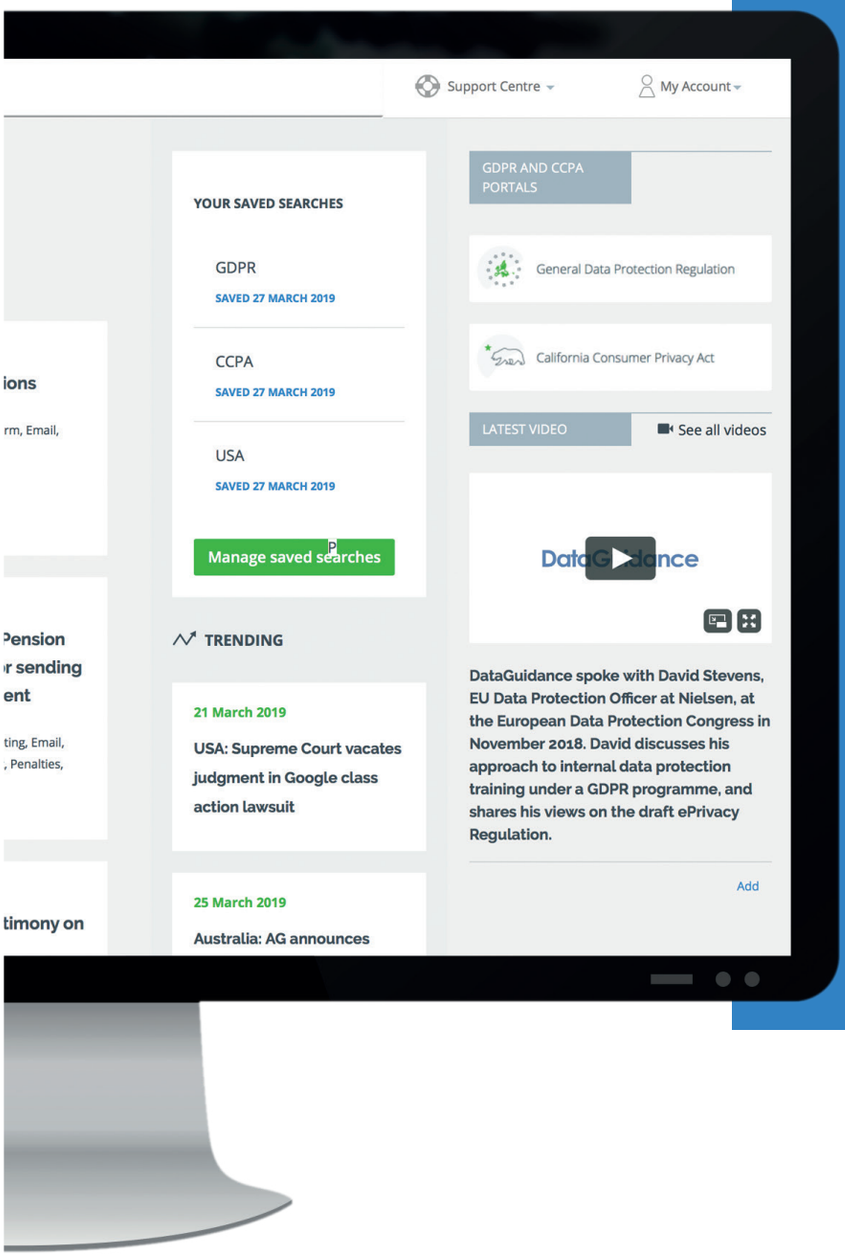
idance

by OneTrust

ataforma usada por profissionais de privacidade

egulatórios,

conformidade global.




# GDPR

## avaliação comparativa

Um novo gráfico para ajudar as organizações a compreender e comparar as principais disposições do GDPR com as leis de proteção de dados relevantes em todo o mundo.

- Compare os requisitos do GDPR com a Califórnia, Japão e Brasil com uma ferramenta comparativa dedicada
- Empregue orientações específicas do tópico para desenvolver suas atividades de conformidade
- Monitore notícias e acesse opiniões escritas sobre os desenvolvimentos mais recentes

DataGuidance

by OneTrust

www.dataguidance.com

| GDPR | LGPD |
| --- | --- |
| **Semelhanças (continuação)** | |
| Outros motivos com base nos quais as transferências de dados são permitidas são: (i) instrumentos juridicamente vinculativos e executórios entre autoridades ou organismos públicos; e (ii) sujeito à autorização da autoridade de supervisão competente por: (a) cláusulas contratuais entre o controlador<br><br>ou o processador e o responsável pelo tratamento, o processador ou o destinatário dos dados pessoais no país terceiro ou organização internacional; ou b) Disposições a incluir nos acordos administrativos entre autoridades ou organismos públicos. | Outros motivos com base nas quais as transferências de dados são permitidas são: (i) cláusulas contratuais específicas para uma transferência específica; (ii) quando a autoridade supervisora autoriza a transferência; (iii) quando a transferência resultar de compromisso assumido em acordo de cooperação internacional; e (iv) quando a transferência for necessária ao cumprimento de uma obrigação legal ou regulamentar por parte do controlador. |
| **Diferenças** | |
| Outros motivos do GDPR incluem: ( i) a transferência é<br>Elaborado a partir de um registo que, de acordo com a legislação da União ou dos Estados-Membros, se destina a fornecer informações ao público e que está aberto à consulta; e (ii) com base no interesse legítimo do responsável pelo tratamento, se a transferência não for repetitiva, diz respeito apenas a um número limitado de titulares dos dados e o responsável pelo tratamento avaliou todas as circunstâncias que envolvem a transferência de dados e, com base nessa avaliação, forneceu salvaguardas adequadas no que diz respeito à protecção de dados pessoais. | A LGPD não prevê a transferência internacional de dados com base em um registro que se destina a fornecer informações ao público, nem com base no interesse legítimo do responsável pelo tratamento. |

## 4.2. Registros de processamento de dados



Razoavelmente consistente

Tanto o GDPR quanto o LGPD estabelecem uma obrigação legal para os controladores e processadores de manter um registro das atividades de processamento sob sua responsabilidade. O GDPR detalha as informações que precisam ser registradas, enquanto o LGPD não fornece esses detalhes.

| GDPR | LGPD |
| --- | --- |
| Artigo 30 | Artigo 37 |
| Considerando 82 | |

### Semelhanças

De acordo com o GDPR, os controladores e processadores devem manter um registro de suas atividades de processamento.

De acordo com a LGPD, os controladores e processadores devem manter registros das operações de processamento de dados pessoais por eles realizadas, especialmente quando baseadas em interesses legítimos.

### Diferenças

De acordo com o GDPR, as organizações que empregam menos de 250 pessoas não precisam manter esse registro, a menos que 'o processamento possa resultar em um risco para os direitos e liberdades dos titulares dos dados, o processamento não seja ocasional ou o processamento inclua categorias especiais de dados conforme referido no artigo 9.o, n.o 1, ou dados pessoais relativos a condenações penais e infrações a que se refere o artigo 10.o »

De acordo com a LGPD, todas as organizações, independentemente de seu tamanho, número de funcionários ou tipo de dados, precisam cumprir a obrigação de processamento de registros. No entanto, isenções podem ser estabelecidas pela autoridade supervisora.

O GDPR estabelece que os controladores de dados devem registrar:

a) o nome e detalhes de contato do controlador; b) as finalidades do processamento; c) uma descrição das categorias de titulares de dados e das categorias de dados pessoais; d) as categorias de destinatários a quem os dados pessoais serão divulgados; e) transferências internacionais de dados pessoais, com a identificação de terceiros países ou organizações internacionais, e a documentação das salvaguardas adequadas adotadas; f) os prazos estimados para o apagamento das categorias de dados; e g) uma descrição geral das medidas técnicas e organizacionais de segurança adotadas.

O LGPD não detalha as informações que os controladores precisam registrar.

O GDPR estabelece que os processadores de dados devem registrar:

a) o nome e detalhes de contato do processador; b) as categorias de processamento realizadas em nome de cada controlador; c) transferências internacionais de dados pessoais, com o

O LGPD não detalha as informações que os processadores precisam registrar.

| GDPR | LGPD |
| --- | --- |
| **Diferenças (continuação)** | |
| identificação de países terceiros ou organizações internacionais, e a documentação de salvaguardas adequadas<br>adotado; ed) uma descrição geral das medidas técnicas e organizacionais de segurança adotadas. | |

## 4.3. Avaliação do impacto da proteção de dados



Bastante inconsistente

Tanto o GDPR como o LGPD estabelecem o requisito de realização de um DPIA para avaliar o risco das atividades de processamento de dados para os direitos e liberdades dos titulares dos dados em circunstâncias específicas.

O GDPR especifica os casos em que um DPIA é necessário, enquanto o LGPD estabelece menos critérios do que o GDPR para quando um DPIA deve ser realizado.

| GDPR | LGPD |
|---|---|
| **Artigos 35-36**<br>**Considerandos 75, 84, 89-93** | **Artigos 5, 10, 38** |

### Semelhanças

| | |
|---|---|
| O GDPR estabelece o requisito para um DPIA a ser conduzido em circunstâncias específicas. As autoridades de supervisão dos Estados-Membros podem ainda determinar quais as operações de tratamento que requerem um DPIA. | O LGPD estabelece o requisito para um DPIA para ser conduzido em circunstâncias específicas. A autoridade brasileira de proteção de dados ('ANPD') pode determinar quais operações de processamento exigem um DPIA. |

### Diferenças

| | |
|---|---|
| O GDPR afirma que um DPIA é 'uma avaliação do impacto das operações de processamento previstas na proteção de dados pessoais.' | A LGPD prevê que DPIA é a documentação do controlador que contém a descrição dos procedimentos de tratamento dos dados pessoais que podem gerar riscos às liberdades civis e aos direitos fundamentais, bem como as medidas, salvaguardas e mecanismos de mitigação do risco. |
| O GDPR afirma que um DPIA é obrigatório: a) quando for provável que o tratamento resulte em alto risco para os direitos e liberdades das pessoas físicas; b) quando se trate de uma avaliação sistemática e extensa de aspectos pessoais relativos a pessoas físicas, a qual se baseia em tratamento automatizado; c) processamento em grande escala de categorias especiais de dados; ed) monitoramento sistemático de uma área acessível ao público em grande escala. | O LGPD não estabelece quando um DPIA é necessário, mas o A ANPD pode solicitar que o controlador execute e forneça um DPIA. |
| O GDPR afirma que um DPIA deve incluir pelo menos: (i) uma descrição sistemática das operações de processamento estimadas e das finalidades do processamento; (ii) uma avaliação da necessidade e proporcionalidade das operações de processamento em relação aos fins; e (iii) uma avaliação dos riscos para os direitos e liberdades dos titulares dos dados. | De acordo com o LGPD, o DPIA deve incluir pelo menos: (i) uma descrição dos tipos de dados processados; (ii) os métodos usados para coletar os dados; (iii) os métodos de segurança da informação utilizados; e (iv) a descrição dos mecanismos utilizados para mitigar os riscos relacionados com o tratamento dos dados pessoais envolvidos. |

| GDPR | LGPD |
| --- | --- |
| **Diferenças (continuação)** | |
| As medidas contempladas para enfrentar os riscos incluem salvaguardas, medidas de segurança e mecanismos para garantir a proteção dos dados pessoais e comprovar o cumprimento do RGPD. | A LGPD não inclui quaisquer disposições explícitas sobre as medidas a serem tomadas para mitigar os riscos. |
| De acordo com o GDPR, o controlador deve consultar a autoridade de supervisão antes do processamento, quando um DPIA indica que o processamento resultaria em um risco elevado na ausência de medidas tomadas pelo controlador para mitigar o risco. | A LGPD não estabelece um processo de consulta prévia sobre DPIAs. |

## 4,4. Nomeação de oficial de proteção de dados



Bastante inconsistente

O GDPR e o LGPD prevêem a nomeação de um DPO. Embora as tarefas que se espera que desempenhem sejam bastante semelhantes em ambas as leis, a natureza e o escopo de suas funções e responsabilidades são diferentes.

| GDPR | LGPD |
|---|---|
| **Artigos 13-14, 37-39**<br>**Considerando 97** | **Artigos 5, 41** |

### Semelhanças

| | |
|---|---|
| O GDPR prevê a nomeação de um DPO. | O LGPD prevê a nomeação de um DPO. |
| O GDPR define as tarefas de um DPO, que incluem: (i) informar e aconselhar o controlador ou processador de suas obrigações sob o GDPR; (ii) monitorar conformidade com a legislação de proteção de dados e sensibilizar / formar o pessoal envolvido nas operações de processamento; (iii) dar conselhos em DPIAs quando solicitado; e (iv) atuar como o ponto de contato para titulares de dados e autoridades de supervisão. | O LGPD define as atividades do DPO, que incluem: (i) aceitar reclamações e comunicações dos titulares dos dados, prestar esclarecimentos e adotar providências; (ii) recebendo comunicações da autoridade de fiscalização, aconselhar os trabalhadores da entidade e terceiros sobre as práticas de proteção de dados, e cumprir as demais atribuições determinadas pelo controlador; (iii) orientar a entidade funcionários e contratados em relação às práticas a serem adotadas em relação à proteção de dados pessoais; e (iv) realizando outras funções conforme determinado pelo controlador ou estabelecido em normas complementares. |
| O controlador de dados e / ou o processador de dados deve publicar os detalhes de contato do DPO como parte de seu aviso de privacidade e comunicá-los à autoridade supervisora. | A identidade e os dados de contato do DPO devem ser divulgados publicamente, de forma clara e objetiva, preferencialmente no site do controlador. |

### Diferenças

| | |
|---|---|
| O GDPR não inclui uma definição de um DPO. | O LGPD inclui uma definição de um DPO, nomeadamente uma pessoa designada pelo controlador, que atua como um canal de comunicação entre o controlador, os titulares dos dados e a autoridade de supervisão. |
| Sob o GDPR, ambos controladores e processadores estão sob a obrigação de nomear um DPO em circunstâncias específicas. | Sob o LGPD, apenas controladores deve nomear um DPO. |
| De acordo com o GDPR, as obrigações de nomear um DPO se aplicam apenas. O LGPD não limitar a nomeação do DPO para controladores e processadores específicos, cujas atividades principais consistem qualquer uma das operações de processamento que requerem regular e monitoramento sistemático de titulares de dados em grande escala, ou | circunstâncias; sendo deixado para a ANPD liberar regras complementares sobre as situações em que poderá ser dispensada a indicação de tal pessoa, de acordo com o |

| GDPR | LGPD |
| --- | --- |
| **Diferenças (continuação)** | |
| processamento em grande escala de categorias especiais de dados e dados pessoais relativos a condenações criminais. | natureza e o tamanho da entidade ou o volume das operações de processamento de dados. |
| Um grupo de empresas pode nomear um RPD, desde que o RPD seja facilmente acessível a partir de cada estabelecimento. | O LGPD faz não mencionar explicitamente se um grupo de entidades pode nomear um único DPO. |
| O GDPR estabelece a independência do DPO. | O LGPD faz não estabelecer explicitamente a independência do DPO. |
| O GDPR afirma que o DPO deve ser fornecido com recursos monetários e humanos para cumprir suas tarefas. | O LGPD faz não incluir qualquer disposição que preveja recursos monetários e humanos a serem dados ao DPO para cumprir suas tarefas. |

## 4.5. Segurança de dados e violações de dados



Razoavelmente consistente

Tanto o GDPR quanto o LGPD incluem a obrigação de os controladores e processadores adotarem medidas de segurança para proteger os dados pessoais que estão processando. A LGPD especifica que a ANPD tem competência para divulgar orientações sobre as medidas de segurança específicas a serem adotadas.

No que diz respeito à notificação de violação de dados, tanto o GDPR como o LGPD incluem a obrigação de notificar a autoridade de supervisão, bem como os titulares dos dados afetados em determinadas circunstâncias. No entanto, embora o GDPR inclua um cronograma definido para notificar no LGPD, o prazo é deixado para a ANPD estabelecer.

Além disso, ao abrigo do LGPD, uma violação de dados deve ser sempre comunicada aos titulares dos dados, enquanto este não é o caso ao abrigo do GDPR.

| GDPR | LGPD |
|---|---|
| **Artigos 5, 24, 32-34, considerandos 74-77, 83-88** | **Artigos 6, 46** |

### Semelhanças

O GDPR reconhece integridade e confidencialidade como princípios fundamentais de proteção de dados, declarando que os dados pessoais devem ser processados de uma maneira que garanta a segurança adequada dos dados pessoais, incluindo proteção contra processamento não autorizado ou ilegal e contra perda acidental, destruição ou dano, usando apropriado medidas técnicas ou organizacionais.

O LGPD reconhece segurança como princípio fundamental de proteção de dados, afirmando que segurança significa o uso do medidas técnicas e administrativas que são capazes para proteger os dados pessoais de acessos não autorizados e situações acidentais ou ilegais de destruição, perda, alteração, comunicação ou disseminação.

O GDPR afirma que controladores de dados e processadores de dados devem adotar segurança técnica e organizacional medidas que garantem um nível de segurança apropriado para o risco tendo em conta o estado da técnica, os custos de implementação e a natureza, âmbito, contexto e objetivos do processamento, bem como o risco de probabilidade e gravidade variáveis para os direitos e liberdades das pessoas singulares.

O LGPD afirma que controladores e processadores devem adotar medidas de segurança, técnicas e administrativas capaz para proteger os dados pessoais de acessos não autorizados e situações acidentais ou ilegais de destruição, perda, alteração, comunicação ou qualquer tipo de processamento impróprio ou ilícito.

De acordo com o GDPR, em caso de violação de dados, o controlador de dados deve notificar a autoridade supervisora competente a menos que É improvável que a violação de dados pessoais resulte em risco para o titular dos dados. O controlador de dados também deve notificar o titulares de dados envolvidos, sem demora indevida, quando a violação de dados pessoais pode resultar em um alto risco.

Sob o LGPD, controladores deve comunicar-se à ANPD e para o titular dos dados a ocorrência de um incidente de segurança que podem criar riscos ou danos relevantes para os titulares dos dados.

| GDPR | LGPD |
|---|---|

## Semelhanças (continuação)

| | |
|---|---|
| A notificação deve incluir, no mínimo: ( i) descrição da natureza da violação, incluindo, sempre que possível, as categorias e o número aproximado da pessoa em causa, e as categorias e número aproximado de registros de dados pessoais em questão; (ii) detalhes de contato do DPO ou outro ponto de contato; (iii) as prováveis consequências do | A comunicação deve incluir, no mínimo: ( I a descrição da natureza dos dados pessoais afetados; (ii) informações sobre os titulares dos dados envolvidos; (iii) a indicação das medidas técnicas e de segurança utilizadas para a proteção dos dados, sob reserva do sigilo comercial e industrial; (iv) os riscos relacionados ao incidente; (v) os motivos do atraso, |
| violação; (iv) medidas tomadas ou propostas a serem tomadas para mitigar os casos em que a comunicação não foi imediata; os possíveis efeitos adversos; e (v) o motivo do atraso. | e (vi) as medidas que foram ou serão adotadas para reverter ou mitigar os efeitos do dano. |

## Diferenças

| | |
|---|---|
| O GDPR fornece uma lista de medidas de segurança que o controlador e o processador podem implementar, que incluem: (i) a pseudonimização e criptografia de dados pessoais dados; (ii) medidas que garantam a confidencialidade, integridade e disponibilidade e resiliência contínuas dos sistemas e serviços de processamento; e (iii) medidas que restaurem a disponibilidade e o acesso aos dados pessoais em tempo hábil no caso de um incidente físico ou técnico. | A ANPD pode fornecer padrões técnicos mínimos tendo em conta a natureza da informação tratada, as características específicas do tratamento e o estado atual da tecnologia, especialmente no caso de dados pessoais sensíveis, bem como os princípios previstos no caput do artigo 6.º |
| O GDPR define aa prazo notificar a autoridade nacional competente como ' Sem demora injustificada e, quando viável, não depois de 72 horas depois de ter se dado conta disso. ' | A LGPD afirma que a comunicação à ANPD deve ser feita em um período de tempo razoável a ser definida. |
| O GDPR afirma que o controlador e o processador deve tomar medidas para garantir que qualquer pessoa singular que atue sob a autoridade do responsável pelo tratamento ou do processador e que tenha acesso aos dados pessoais não os trate, exceto por instruções do responsável pelo tratamento, a menos que seja obrigada a fazê-lo pela União ou pelo Estado-Membro lei. | A LGPD afirma que os agentes de processamento ou qualquer outra pessoa que intervenha numa das fases do processamento se comprometem a garantir a segurança das informações relativas aos dados pessoais, mesmo após a sua conclusão. |
| O GDPR inclui disposições específicas em relação à notificação de uma violação de dados pessoais aos titulares dos dados. | A LGPD não inclui mais detalhes no que diz respeito à comunicação de uma violação de dados dirigida diretamente aos titulares dos dados. |

# 4,6. Responsabilidade e boas práticas



**Bastante inconsistente**

Tanto o GDPR quanto o LGDP reconhecem a responsabilidade como um princípio fundamental de privacidade. O LGPD afirma que os controladores e processadores podem adotar programas de governança de privacidade e boas práticas para obter responsabilidade, enquanto o GDPR não se refere a tais medidas.

| GDPR | LGPD |
|---|---|
| **Artigos 5, 24-25**<br>**Considerando 39** | **Artigos 6, 50** |

## Semelhanças

O GDPR reconhece prestação de contas como princípio fundamental da protecção de dados. O artigo 5 afirma que "o responsável pelo tratamento deve ser responsável e capaz de demonstrar o cumprimento das leis de proteção de dados".

O LGPD reconhece prestação de contas como princípio fundamental da protecção de dados. O artigo 6º estabelece que a responsabilização é a demonstração, pelo agente de processamento, da adoção de medidas eficazes e capazes de comprovar o cumprimento das regras de proteção de dados pessoais, incluindo a eficácia de tais medidas.

## Diferenças

O GDPR esclarece que o controlador de dados deve implementar medidas que garantam e demonstrem conformidade. Refere-se à proteção de dados desde a concepção e por padrão, a implementação de políticas de proteção de dados e a adesão a códigos de conduta. No entanto, não especifica

com quais atividades o controlador de dados deve se envolver.

A LGPD esclarece que os controladores e processadores podem adotar processos e políticas internas que garantam o amplo cumprimento das regras e boas práticas, que incluem um programa de governança de privacidade, e medidas que demonstrem sua eficácia. O programa de governança pode: (i) demonstrar o compromisso do controlador em adotar processos e políticas internas que garantam o amplo cumprimento das regras e boas práticas relativas à proteção de dados pessoais; (ii) é aplicável a todo o conjunto de dados pessoais sob seu controle, independentemente do meio utilizado para coletá-los; (iii) está adaptado à estrutura, escala e volume de suas operações, bem como à sensibilidade dos dados processados; (iv) estabelece políticas e salvaguardas adequadas com base em um processo de avaliação sistemática dos impactos e riscos à privacidade; (v) tem por objetivo estabelecer uma relação de confiança com o titular dos dados, através da transparência, e que garanta mecanismos para a participação do titular dos dados; (vi) integra-se à sua estrutura geral de governança e estabelece e aplica mecanismos internos e externos de supervisão; (vii) possui planos de resposta a incidentes e solução; e (viii) é constantemente atualizado com base em informações obtidas em monitoramento contínuo e avaliações periódicas.

# 5. Direitos dos indivíduos

## 5.1. Direito de apagar




Tanto o GDPR quanto o LGPD permitem que indivíduos solicitem a exclusão de suas informações pessoais, a menos que haja exceções.

Deve-se observar que o escopo, a aplicabilidade e as isenções ao direito de apagamento variam entre os dois atos legislativos. No entanto, algumas exceções são semelhantes, como quando o tratamento de dados pessoais é feito para fins de pesquisa, jornalísticos, artísticos ou acadêmicos, ou quando é necessário cumprir uma obrigação legal.

| GDPR | LGPD |
|---|---|
| **Artigos 12, 17**<br>**Considerandos 59, 65-66** | **Artigos 5, 16, 18** |

**Semelhanças**

O GDPR fornece aos indivíduos o certo para solicitar que seus dados sejam apagados.

O LGPD fornece aos indivíduos o certo para solicitar que seus dados sejam excluídos.

O direito de apagar se aplica se certos motivos aplicar, como onde o consentimento foi retirado e não há outro fundamento legal para o processamento, ou quando dados pessoais não são mais necessário para o fim para o qual foi recolhido.

De acordo com o LGPD, o direito de solicitar exclusão aplica-se a dados desnecessários ou excessivos, ou dados processados com o consentimento do titular dos dados, exceto nas situações previstas no Artigo 16.

O escopo deste direito não se limita ao controlador de dados, mas também destinatários, processadores de dados e subprocessadores que podem ter que cumprir com solicitações de eliminação.

O escopo deste direito não se limita aos impactos dos dados terceiros, como controlador, mas também impacta processadores com quem o dados foram compartilhados. Os controladores devem informar imediatamente os agentes de processamento com os quais os dados pessoais foram partilhados do pedido de eliminação dos titulares dos dados, para que possam repetir o mesmo procedimento.

Este direito pode ser exercido grátis. Pode haver alguns casos, no entanto, em que uma taxa pode ser solicitada, principalmente quando os pedidos são infundados, excessivos ou de natureza repetitiva.

Este direito pode ser exercido grátis.

O titular dos dados deve ser informado que eles têm o direito de solicitar a exclusão de seus dados.

O titular dos dados deve ser informado que eles têm o direito de solicitar a exclusão de seus dados.

O GDPR inclui alguns isenções à aplicação do direito de apagamento. Entre as exceções ao direito de apagamento fornecido pelo GDPR incluem: (i) liberdade de expressão e liberdade de informação, incluindo jornalístico,

O LGPD inclui alguns isenções à aplicação do direito de apagamento. Entre as exceções ao direito de apagamento fornecido pela LGPD incluem: (i) onde o armazenamento de dados pessoais foi autorizado para um estudo por uma entidade de pesquisa, ou (ii) para cumprir

| GDPR | LGPD |
| --- | --- |
| **Semelhanças (continuação)** | |
| expressão acadêmica, artística e ou literária; (ii) processamento para propósitos de pesquisa de dados pessoais que, se apagados, prejudicariam os objetivos da pesquisa; e para (iii) cumprir uma obrigação legal. Além disso, o GDPR prevê que podem ser impostas restrições pela legislação da União ou dos Estados-Membros, na medida do necessário e proporcionado de uma forma democrática | com uma obrigação legal ou regulatória pelo controlador.<br>Além disso, o direito de exclusão não se aplica ao tratamento de dados pessoais que seja feito exclusivamente para fins jornalísticos e artísticos ou acadêmicos. Além disso, o direito de exclusão não se aplica ao processamento de dados pessoais que é feito para fins |
| sociedade para salvaguardar: segurança nacional, defesa, segurança pública, a prevenção, investigação e repressão de<br>ofensas criminais ou a execução de penas criminais. | do segurança pública, defesa nacional, segurança do estado ou investigação e repressão de infrações penais. |
| **Diferenças** | |
| Os pedidos dos titulares dos dados ao abrigo deste direito devem ser respondidos sem atrasos indevidos e, em qualquer caso, dentro de 1 mês a partir do recebimento da solicitação. ' O prazo pode ser estendido para 2 meses adicionais tendo em conta a complexidade e o número de pedidos. Em qualquer caso, o titular dos dados deve ser informado dessa prorrogação no prazo de um mês a partir da recepção do pedido. | Os controladores de dados devem responder imediatamente a uma solicitação do titular dos dados. Caso tal não seja possível, o responsável pelo tratamento deve: (i) enviar resposta ao titular dos dados em que comunica que não é o agente de processamento de dados e indicar, sempre que possível, quem é o agente; ou (ii) indicar as razões de fato ou de direito que impedem a adoção imediata da medida. |
| O GDPR especifica que os controladores de dados devem ter mecanismos para garantir que o pedido é feito pelo titular dos dados cujos dados pessoais devem ser apagados. | Não é necessário criar mecanismos para identificar o titular dos dados cujos dados pessoais devem ser apagados. |
| Os métodos para enviar uma solicitação incluem escrita, oralmente e por outro meios, que incluem meios eletrônicos quando for apropriado. | O direito de exclusão deve ser exercido por meio de um pedido expresso pelo titular dos dados. |
| Exceções: Além das exceções enumeradas em 'Similaridades', um controlador de dados também está isento de cumprir com os pedidos de eliminação por motivos de público<br>interesse pela área de saúde pública; estabelecimento, ou para o exercício ou defesa de ações judiciais. | Exceções: Além das exceções enumeradas em 'Similaridades', o direito de exclusão não se aplica quando o processamento de dados pessoais é feito por uma pessoa física<br>exclusivamente para fins privados e não econômicos, ou<br>onde os dados pessoais foram autorizados a serem armazenados para os seguintes fins: transferir para terceiros, desde que sejam cumpridos os requisitos de processamento de dados; e uso exclusivo do controlador com o acesso de terceiros proibido e desde que os dados sejam anonimizados. |

## 5,2 Direito de ser informado



**Razoavelmente consistente**

O GDPR e o LGPD apresentam um elevado grau de semelhança no que diz respeito ao princípio da transparência. Notavelmente, ambas as leis exigem que os controladores forneçam aos indivíduos um aviso de privacidade detalhado com informações sobre o processamento de seus dados pessoais.

No entanto, a LGPD não aborda explicitamente as obrigações de transparência para a coleta indireta de dados pessoais.

| GDPR | LGPD |
|---|---|
| **Artigos 5, 12-14** | **Artigos 6, 9-10, 14, 18-19** |
| **Considerandos 58-63** | |

### Semelhanças

| | |
|---|---|
| O GDPR inclui ' transparência' como um dos princípios chave de processamento de dados, ao afirmar que 'os dados pessoais serão processados de forma legal, justa e transparente em relação ao titular dos dados'. | O LGPD inclui transparência como um dos princípios chave do tratamento de dados, ao afirmar que a transparência é a garantia aos titulares dos dados de informação clara, precisa e facilmente acessível sobre a realização do tratamento e respectivos agentes de tratamento, sujeita ao sigilo comercial e industrial. |
| O GDPR especifica que os titulares dos dados têm o direito de ter acesso às informações relativas ao processamento dos seus dados pessoais. Em particular, eles devem ter acesso a: (i) o propósitos do processamento; (ii) o período de retenção de dados; (iii) o identidade do controlador de dados; ( iv) o destinatários ( ou deles categorias) de dados pessoais; e (v) o direitos dos titulares dos dados. | A LGPD especifica que os titulares dos dados têm o direito de acesso às informações relativas ao tratamento dos seus dados pessoais. Em particular, eles devem ter acesso a: (i) o propósito específico do processamento; (ii) o duração do processamento, sendo observado sigilo comercial e industrial; (iii) a identidade do controlador; (iv) informações sobre o uso compartilhado de dados pelo controlador e pela finalidade; e (v) o direitos dos titulares dos dados, com menção explícita dos direitos previstos no Artigo 18. |
| O GDPR especifica que as informações fornecidas ao titular dos dados devem ser fornecidas em um conciso, facilmente acessível e em linguagem simples. | A LGPD especifica que as informações fornecidas ao titular dos dados devem ser fornecidas em uma clara, forma adequada e ostensiva. |
| Para consentimento para ser válido deve ser informado. | Quando a atividade de processamento é baseada em consentimento, será considerado nulo se a informação fornecida ao titular dos dados contiver conteúdo enganoso ou abusivo ou não tiver sido previamente apresentada de forma transparente, clara e inequívoca. Além disso, nos casos em que o consentimento é necessário, se houver alterações na finalidade do tratamento de dados pessoais que não sejam compatíveis com o consentimento original, o responsável pelo tratamento deve informar previamente o titular dos dados sobre as alterações de |

| GDPR | LGPD |
| --- | --- |
| **Semelhanças (continuação)** | |
| | propósito, e o titular dos dados pode revogar o seu consentimento se discordar das alterações. |
| Quando o processamento é baseado em interesse legítimo, o interesse legítimo do controlador de dados e de terceiros deve ser especificado no aviso de privacidade. | Quando a atividade de processamento é baseada em interesse legítimo, o controlador deve adotar medidas para garantir a transparência do processamento de dados. |
| **Diferenças** | |
| Outras informações que precisam ser incluídas, conforme declarado no GDPR, no aviso de privacidade são: (i) o categorias de pessoal dados; (ii) detalhes de contato do DPO; ( iii) o transferência de dados para países terceiros; (iv) o direito de retirar o consentimento a qualquer momento; (v) o direito de apresentar uma reclamação com uma autoridade supervisora; (vi) quando o processamento de dados é baseado em um contrato as consequências de não fornecer os dados pessoais; e (vii) a existência de tomada de decisão automatizada, Incluindo perfil, o lógica envolvidos e o consequências. Caso os dados pessoais não sejam coletados diretamente do titular dos dados, o fonte dos dados devem ser incluídos. | Outras informações que precisam ser incluídas, conforme declarado no LGPD, no aviso de privacidade são: (i) o tipo de processamento; (ii) a detalhes de contato do controlador; e (iii) responsabilidades dos agentes que realizará o processamento. |
| O GDPR aborda explicitamente as obrigações de transparência para coleção indireta de dados pessoais. | O LGPD faz não abordar explicitamente as obrigações de transparência para coleção indireta de dados pessoais. |
| Quando o processamento de dados pessoais envolve dados pessoais das crianças, ' qualquer informação e a comunicação [...] deve ser em uma linguagem clara e simples que a criança possa entender facilmente. ' | Quando o processamento de dados pessoais envolve infantil e dados pessoais de adolescentes, controladores devem fazer público a informação sobre os tipos de dados recolhidos, a forma como são utilizados e as modalidades de exercício dos direitos a que se refere o artigo 18.º da LGPD. |

## 5,3. Direito de objetar




Tanto o GDPR quanto o LGPD fornecem aos titulares dos dados o direito de se opor ao processamento de seus dados pessoais.

Além disso, o GDPR fornece explicitamente o direito de cancelamento no contexto do marketing direto.

| GDPR | LGPD |
|---|---|
| **Artigos 7, 18, 21** | **Artigos 15, 18** |

### Semelhanças

| | |
|---|---|
| Os controladores não devem mais processar dados pessoais quando solicitados pelo titular dos dados e nas circunstâncias previstas na lei. | Os controladores e processadores são obrigados a encerrar o processamento de dados pessoais mediante comunicação do titular dos dados, inclusive ao exercer seus direitos de revogar o consentimento. |
| Em formação sobre esses direitos e como exercê-los devem ser incluídos no aviso de privacidade. | Em formação sobre este direito deve ser disponibilizado ao titular dos dados de forma clara, adequada e ostensiva. |
| Este direito deve ser exercido grátis. | Este direito deve ser exercido grátis. |
| Os pedidos dos titulares dos dados ao abrigo deste direito devem ser respondidos sem atrasos indevidos e, em qualquer caso, dentro de 1 mês a partir do recebimento da solicitação. ' O prazo pode ser estendido para 2 meses adicionais tendo em conta a complexidade e o número de pedidos. Em qualquer caso, o titular dos dados deve ser informado dessa prorrogação no prazo de um mês a partir da recepção do pedido. | Os controladores de dados devem responder imediatamente a uma solicitação do titular dos dados. Caso não seja possível, o responsável pelo tratamento deve enviar uma resposta ao titular dos dados na qual comunica que não é o agente de processamento de dados e indicar, sempre que possível, quem é o agente; ou indicar as razões de fato ou de direito que impedem a adoção imediata da medida. |

### Diferenças

| | |
|---|---|
| Os titulares dos dados têm o direito de objeção ao processamento de dados pessoais é processado com base no interesse legítimo ou interesse público. Ao exercer esse direito, o controlador é obrigado a interromper o processamento, a menos que demonstre motivos que anulam a solicitação do titular dos dados. | Os titulares dos dados têm o direito de se opor ao processamento Realizado com base em uma das situações distintas do consentimento, se houver descumprimento da LGPD. |
| O GDPR concede aos titulares dos dados o direito de se opor ao processamento de seus dados para fins de marketing direto. Em particular, no contexto do marketing direto, optar pela exclusão deve ser tão fácil quanto optar pela inclusão. | O LGPD faz não abordar objeções ao marketing direto especificamente. |

## 5,4 Direito de acesso



Bastante inconsistente

O direito de acesso é reconhecido no GDPR e no LGPD, no sentido de que as organizações devem fornecer aos indivíduos acesso aos seus dados pessoais quando solicitado.

Existem várias diferenças entre os dois atos legislativos, incluindo o período de tempo durante o qual um pedido de acesso deve ser respondido, as informações que devem ser incluídas na resposta e as limitações ao direito.

| GDPR | LGPD |
|---|---|
| **Artigos 12, 15** | **Artigos 6, 18, 19** |
| **Considerandos 59-64** | |

### Semelhanças

| | |
|---|---|
| O GDPR reconhece que os titulares dos dados tenham o direito de acesso seus dados pessoais sendo processados pelo controlador de dados. | O LGPD reconhece que os titulares dos dados tenham o direito de acesso seus dados sendo processados pelo controlador de dados. |
| O GDPR afirma que, ao responder a uma solicitação de acesso, um controlador de dados deve indicar o propósitos do processamento; e quaisquer fontes onde os dados foram coletados. | A resposta a uma solicitação de acesso deve incluir uma declaração clara indicando o origem dos dados, a existência de quaisquer registros e o finalidade do processamento. Quando uma resposta é dada imediatamente, o formato pode ser simplificado. |
| O GDPR prevê que o direito de acesso não deve afetar adversamente os direitos ou liberdades de outros, incluindo segredos comerciais. | Ao fornecer informações ao titular dos dados, segredos comerciais e industriais deve ser levado em consideração. |
| Os titulares dos dados devem ter uma variedade de meios através dos quais podem fazer sua solicitação, inclusive por meio meios eletrônicos. | A resposta pode ser fornecida, a critério de o titular dos dados, em formulário impresso, ou pela meios eletrônicos, seguro e adequado para este fim. |
| O GDPR afirma que os titulares dos dados podem exercer esta certo grátis. Lá pode haver alguns casos em que uma taxa pode ser solicitada, nomeadamente quando os pedidos são infundados, excessivos ou de carácter repetitivo. | Os titulares dos dados devem ser garantidos com facilidade e grátis acesso à informação sobre a forma e duração do tratamento, bem como sobre a integralidade dos seus dados pessoais. |

### Diferenças

| | |
|---|---|
| As solicitações dos titulares dos dados devem ser atendidas sem ' atraso indevido e em qualquer evento dentro 1 mês a partir do recebimento da solicitação. ' O prazo pode ser estendido para mais 2 meses levando em consideração a complexidade | O acesso aos dados pessoais deve ser fornecido, a pedido do titular dos dados, dentro de um período de até 15 dias do pedido do titular dos dados, se os dados solicitados forem superiores à versão do pedido simplificado. |

| GDPR | LGPD |
| --- | --- |
| **Diferenças (continuação)** | |
| e número de solicitações. Em qualquer caso, o titular dos dados deve ser informado dessa prorrogação no prazo de um mês a partir da recepção do pedido. | |
| O GDPR especifica que os controladores de dados devem ter mecanismos para garantir que o pedido seja feito pelo titular dos dados cujos dados pessoais é solicitado o acesso. | A LGPD não exige explicitamente que as organizações tenham mecanismos para garantir que a solicitação seja feita pelo titular dos dados. No entanto, a LGPD afirma que o direito de acesso deve ser exercido sobre O expresso pedido do titular dos dados ou do seu representante legal. |
| Os titulares dos dados devem ter uma variedade de meios para fazer sua solicitação, incluindo oralmente. | O LGPD faz não fornecer explicitamente pedidos orais. |
| Quando a solicitação de acesso for feita por meio eletrônico, o controlador de dados deve apresentar a resposta pelos mesmos meios. | Há sim não exigência da LGPD de que as solicitações eletrônicas sejam atendidas nos mesmos meios. |
| O GDPR afirma que, ao responder a um acesso solicitação, um controlador de dados deve indicar a categorias de dados pessoais em questão; a destinatários ou categorias de destinatários a quem os dados pessoais foram divulgados; a período de retenção; a direito de apresentar queixa à autoridade de controlo; a existência de tomada de decisão automatizada; e a existência de transferência de dados. | O LGPD apenas exige explicitamente que as organizações forneçam informações sobre origem dos dados, a existência de quaisquer registros e o propósito do processamento quando uma declaração completa é feita. |
| Os controladores de dados podem recusar-se a agir em um pedido quando é manifestamente infundado, excessivo ou tem um repetitivo personagem. | O LGPD faz não inclua uma lista de razões para recusar um pedido de acesso. |
| O GDPR afirma que o direito de acesso não deve afetar negativamente os direitos ou liberdades de terceiros. Bem como segredos comerciais (em 'Similaridades'), isso inclui propriedade intelectual e em particular o software de proteção de direitos autorais. | O LGPD faz não incluir uma lista de direitos e liberdades que precisam ser comparados com o direito de acesso. Em relação aos segredos comerciais, consulte 'Similaridades'. |
| O GDPR faz não incluir qualquer disposição sobre o formato em que as informações devem ser armazenadas em relação a facilitar o acesso do titular dos dados aos seus dados pessoais. | O LGPD afirma que os dados pessoais devem ser armazenado em um formato que favorece o exercício do direito de acesso. |

## 5.5. Direito de não ser sujeito a discriminação para o exercício de direitos




A LGPD reconhece explicitamente o princípio da não discriminação como um princípio fundamental de proteção de dados. Embora o GDPR não reconheça este princípio explicitamente, ele pode ser inferido como parte do princípio sobre o processamento justo de dados pessoais e com base em várias outras disposições do GDPR.

| GDPR | LGPD |
|---|---|
| **Artigos 5, 22** | **Artigos 1-2, 6 (IX), 20** |
| **Considerandos 39, 71-73** | |

### Semelhanças

O GDPR protege os indivíduos do processamento automatizado que pode resultar em uma decisão com efeitos jurídicos ou significativos e que pode ter consequências discriminatórias sobre os indivíduos ao, entre outros, limitar a base jurídica sobre a qual essa atividade de processamento pode ser realizada e ao fornecer aos indivíduos a oportunidade de contestar a decisão e pedir a intervenção humana.

A LGPD estabelece que, quando as decisões são tomadas exclusivamente com base no processamento automatizado de dados pessoais que afetam seus interesses, o titular dos dados tem o direito de solicitar uma revisão da decisão e a autoridade supervisora pode realizar uma auditoria para verificar aspectos discriminatórios em processamento automatizado de dados pessoais.

### Diferenças

O GDPR faz não reconhecer explicitamente a não discriminação como um princípio fundamental, embora seja a base para várias disposições, tais como tratamento justo (artigo 5º), consentimento dado livremente (artigo 7º) e transparência (artigo 13º).

O LGPD explicitamente reconhece o princípio da não discriminação como a impossibilidade de efetuar o tratamento para fins discriminatórios ilegais ou abusivos.

## 5,6. Direito à portabilidade de dados




Tanto o GDPR quanto o LGPD reconhecem o direito à portabilidade dos dados para os titulares dos dados. No entanto, os motivos e o escopo do direito são diferentes.

| GDPR | LGPD |
|---|---|
| **Artigos 12, 20**<br>**Considerando 68** | **Artigos 11, 17-18, 40** |

### Semelhanças

O GDPR fornece aos indivíduos o direito à portabilidade de dados. O LGPD fornece aos indivíduos o direito à portabilidade de dados.

Dados anônimos não está sujeito ao GDPR e, portanto, ao direito de portabilidade de dados.

A portabilidade de dados pessoais não inclui dados que já foram anonimizado pelo controlador.

### Diferenças

O GDPR define o direito à portabilidade de dados como o direito a receber dados processados com base em contrato ou consentimento e processados por meios automatizados, em um 'formato estruturado, comumente usado e legível por máquina' e para transmita esses dados para outro controlador sem obstáculos.

O LGPD define o direito aos dados portabilidade como portabilidade de os dados para outro provedor de serviço ou produto, por meio de um pedido expresso e sujeita ao sigilo comercial e industrial, conforme regulamentação do órgão controlador.

O GDPR faz não limitar explicitamente o escopo do direito de portabilidade de dados a categorias especiais de dados pessoais.

Comunicação ou uso compartilhado entre controladores de pessoal sensível os dados referentes à saúde para fins de obtenção de vantagem econômica são proibidos, exceto nos casos de portabilidade de dados quando consentida pelo titular dos dados ou quando os dados de saúde sejam necessários para garantir a prestação de serviços de saúde suplementar adequados, ou seja, os provisão adequada de planos de saúde.

# ⚠ 6. Aplicação




## 6.1. Penalidades monetárias

Tanto o GDPR como a LGPD prevêem a possibilidade de aplicação de penalidades pecuniárias em caso de incumprimento.

No entanto, a natureza das penalidades, o montante e quem está sujeito a elas diferem.

| GDPR | LGPD |
|---|---|
| **Artigo 83.** **Considerandos 148-149** | **Artigos 52-54** |

### Semelhanças

| | |
|---|---|
| O RGPD prevê a possibilidade de sanções administrativas e pecuniárias a serem aplicadas pelas autoridades de supervisão em caso de incumprimento. | A LGPD prevê a possibilidade de penalidades administrativas e pecuniárias a serem aplicadas pela ANPD nos casos de descumprimento. |
| Quando aplicando uma sanção administrativa, o supervisor autoridade deve considerar: ( i) a natureza, gravidade e duração da infração; (ii) o caráter intencional ou negligente da infração; (iii) qualquer ação tomada para mitigar o dano; (iv) o grau de responsabilidade do controlador ou processador; (v) quaisquer infrações anteriores relevantes; (vi) o grau de cooperação com a autoridade de supervisão; (vii) as categorias de dados pessoais afetados pela infração; (viii) a forma como a infração se tornou conhecida pela autoridade supervisora; ix) Sempre que as medidas referidas no artigo 58.º, n.º 2, tenham sido anteriormente decretadas contra o responsável pelo tratamento ou o subcontratante em causa relativamente ao mesmo objeto, o cumprimento dessas medidas; (x) adesão a códigos de conduta aprovados ou mecanismos de certificação aprovados; | Quando aplicando uma sanção administrativa, a ANPD deve considerar: ( i) a gravidade e a natureza das infrações e dos direitos pessoais afetados; (ii) a boa fé do infrator; (iii) a vantagem obtida ou pretendida pelo infrator; (iv) a condição econômica do infrator; (v) reincidência; (vi) o nível de dano; (vii) a cooperação do infrator; (viii) adoção repetida e comprovada de mecanismos e procedimentos internos capazes de minimizar os danos, para o tratamento seguro e adequado dos dados, de acordo com o disposto no Artigo 48 (2) (II); (ix) adoção de boas práticas e política de governança; (x) a pronta adoção de medidas corretivas; e (xi) a proporcionalidade entre a gravidade da infração e a intensidade da sanção. |
| As autoridades de supervisão podem desenvolver diretrizes que estabeleçam outros critérios para calcular o valor da multa monetária. | A ANPD desenvolverá seu próprio regulamento sobre os critérios de aplicação e cálculo das multas, que deverão ser objeto de consulta pública. |

### Diferenças

| | |
|---|---|
| O GDPR possui apenas uma categoria de multa administrativa, que também se aplica a órgãos governamentais. | A LGPD estabelece dois tipos de multas monetárias: multas simples e diárias, ambas com o mesmo limite de BRL 50.000.000 (aproximadamente € 11.582.750). Uma multa diária normalmente é usado para fazer cumprir uma decisão anterior. |

| GDPR | LGPD |
| --- | --- |
| **Diferenças (continuação)** | |
| Dependendo da violação ocorrida a penalidade pode estar preparado para: 2% do volume de negócios anual global ou € 10 milhões, o que for mais alto; ou 4% do volume de negócios anual global ou € 20 milhões, o que for mais alto. | Dependendo da violação, um simples multa de até 2% das receitas de pessoa jurídica privada, grupo ou conglomerado no Brasil, no exercício anterior, excluindo impostos, até um máximo total de R $ 50.000.000 por infração pode ser emitida. |
| Nos termos do RGPD, cabe aos Estados-Membros criar regras sobre a aplicação de multas administrativas a autoridades e organismos públicos. | De acordo com o LGPD, as agências governamentais não podem ser sancionadas com multas administrativas. |

# 6,2 Autoridade Supervisora



Razoavelmente consistente

Tanto o GDPR quanto o LGPD prevêem o estabelecimento de uma autoridade supervisora com poderes corretivos e investigativos. No entanto, as estruturas e orçamentos podem variar.

| GDPR | LGPD |
|---|---|
| Artigos 51-59 | Artigos 55 AK |

## Semelhanças

| | |
|---|---|
| De acordo com o GDPR, as autoridades de supervisão têm poderes de investigação que incluem: (i) solicitar um controlador e processador para fornecer as informações necessárias; (ii) conduzir auditorias de proteção de dados; (iii) revisão das certificações emitidas; e (iv) obter acesso a todos os dados pessoais e a quaisquer instalações. | No LGPD, a ANPD tem poderes de investigação que incluem solicitar informações, a qualquer momento, de controladores e processadores. |
| De acordo com o GDPR, as autoridades de supervisão têm poderes corretivos que incluem: (i) emitir advertências e repreensões; (ii) imposição de uma limitação temporária ou definitiva, incluindo a proibição de processamento; (iii) ordenar a retificação ou apagamento de pessoal; e (iv) aplicação de multas administrativas. | No LGPD, a ANPD tem poderes corretivos que incluem: (i) a emissão de advertências e multas; (ii) divulgação da infração; e (iii) bloqueio ou eliminação do processamento ou dos dados pessoais a que se refere a infração. |
| Ao abrigo do RGPD, as autoridades de supervisão também devem: (i) tratar as reclamações apresentadas pelos titulares dos dados; e (ii) cooperar com as autoridades de proteção de dados de outros países. | De acordo com a LGPD, a ANPD também deve: (i) tratar as reclamações apresentadas pelos titulares dos dados; e (ii) cooperar com as autoridades de proteção de dados de outros países. |
| Ao abrigo do GDPR, as autoridades de supervisão têm a tarefa de promover a sensibilização e compreensão do público sobre os riscos, regras, salvaguardas e direitos em relação ao processamento, bem como promover a sensibilização dos controladores e processadores para as suas obrigações, entre outras tarefas. | No âmbito da LGPD, a ANPD tem por missão promover a sensibilização do público para a proteção de dados pessoais e de segurança e realizar estudos sobre práticas nacionais e internacionais de proteção de dados pessoais e privacidade, entre outras atribuições. |

## Diferenças

| | |
|---|---|
| Cabe a cada Estado-Membro estabelecer uma autoridade de supervisão e determinar as qualificações exigidas para ser um membro e as obrigações relacionadas com o trabalho, tais como a duração do mandato, bem como as condições para uma nova nomeação. | A ANPD é um órgão da administração pública federal, subordinado ao Conselho de Ministros da Presidência da República. A ANPD é composta pela Diretoria, Conselho Nacional de Proteção e Privacidade de Dados, Ouvidoria, departamento jurídico próprio e departamentos administrativos e especializados necessários à aplicação da LGPD. |

| GDPR | LGPD |
| --- | --- |
| **Diferenças (continuação)** | |
| As autoridades de supervisão podem estar sujeitas ao controle financeiro apenas se isso não afetar sua independência. Eles têm orçamentos públicos anuais separados, que podem fazer parte do orçamento nacional geral. | A ANPD não tem autonomia financeira, e seu orçamento é definido pela Presidência, pois a LGPD não concede claramente um orçamento específico para suas atividades. |

# 6.3. Recursos civis para indivíduos



Razoavelmente consistente

Além das sanções administrativas, qualquer pessoa física tem o direito de buscar indenização por quaisquer danos materiais e imateriais resultantes de uma violação do RGPD ou da LGPD, respectivamente. Ambas as leis permitem ações individuais e coletivas perante o tribunal.

O GDPR especifica como os danos são compensados pelo controlador e pelo processador. O LGPD não aborda esse ponto.

| GDPR | LGPD |
| --- | --- |
| **Artigos 82** | **Artigos 22, 42** |
| **Considerandos 146-147** | |

## Semelhanças

O GDPR fornece aos indivíduos um causa da ação para buscar danos materiais ou imateriais por violação das leis de privacidade perante os tribunais.

O LGPD fornece aos indivíduos um causa da ação buscar danos cíveis (pecuniários ou morais) por violação das leis de privacidade perante os tribunais.

O RGPD permite que os Estados-Membros prevejam a possibilidade de as pessoas em causa conferirem um mandato de representação a uma associação, associação ou organização sem fins lucrativos que tenha por objetivo estatutário a proteção dos direitos das pessoas em causa.

A LGPD prevê que a indemnização civil pode ser reclamada através de instrumentos jurídicos individuais ou coletivos, tais como ações coletivas desencadeadas por associações de defesa dos direitos dos consumidores em nome dos titulares dos dados, mesmo que o titular dos dados não tenha concordado com este direito de ação.

## Diferenças

O GDPR especifica como os danos são compensados pelos controladores e processadores responsáveis pelos danos.

A LGPD não especifica a forma de indenização da indenização, admitindo a indenização com base no Código Civil Brasileiro, que não estabelece limite ou metodologia, com base na jurisprudência.

ORDEM E PROGRESSO